

ALLGEMEINES KI-INFORMATIONSSICHERHEITSKONZEPT

Air-Gap und Cloud-Inferenz

ÖFFENTLICH – organisationsneutrale Referenzvorlage

Version 0.4.0

Vorwort

Dieses KI-Informationssicherheitskonzept ergänzt ein bestehendes Informationssicherheitskonzept um die Nutzung Künstlicher Intelligenz (KI). Es regelt die zulässigen KI-Funktionen, ihre Daten- und Berechtigungsgrenzen sowie die Verantwortlichkeiten für Auswahl, Prüfung, Änderung und Außerbetriebnahme.

Im Air-Gap-Szenario arbeitet die KI vollständig innerhalb einer vom Internet getrennten Umgebung. Im Cloud-Szenario werden ausschließlich freigegebene Eingaben und Kontextausschnitte an einen zugelassenen Modellanbieter übermittelt. Dokumentbestände, Rechteprüfung und Werkzeugausführung bleiben in beiden Szenarien unter betrieblicher Kontrolle.

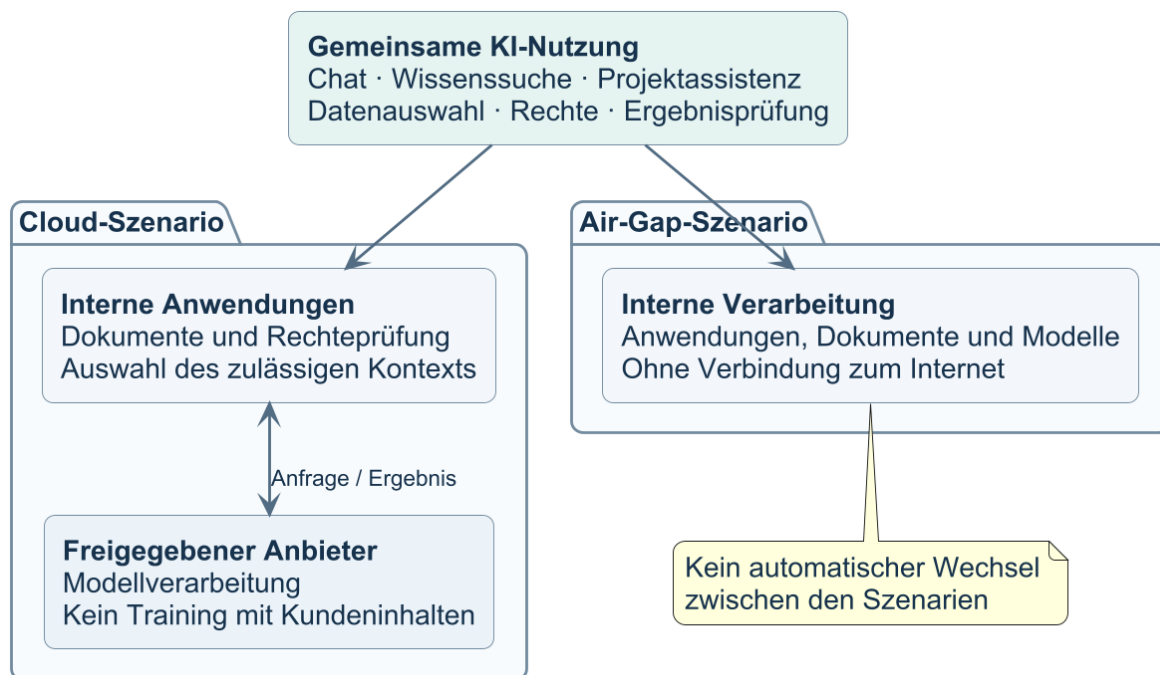


Abbildung 1: Zwei getrennte Referenzszenarien mit gemeinsamen Nutzungsregeln.

Fach- und Datenverantwortliche bestimmen zugelassene Anwendungsfälle und Datenarten. Nutzende legen innerhalb dieses Rahmens den Arbeitsauftrag und die erforderlichen Inhalte fest, prüfen Ergebnisse vor der Verwendung und genehmigen Agentenaktionen innerhalb ihrer Befugnisse. Die Nutzerbelehrung ist als Anlage 1 beigefügt.

Dokumentenlenkung

Merkmal	Festlegung
Dokumenttitel	Allgemeines KI-Informationssicherheitskonzept
Dokumentstatus	ÖFFENTLICH – organisationsneutrale Referenzvorlage
Version	0.4.0
Dokumentdatum	06.10.2026
Geltungsbereich	KI-spezifische Ergänzung des Informationssicherheitskonzepts
Szenarien	Air-Gap und Cloud-Inferenz
Modellnutzung	Inferenz ohne eigenes Training oder Feinabstimmung

Inhaltsverzeichnis

1 Geltungsbereich	5
2 Nutzungskonzept	5
3 Mitgeltende Vorgaben	5
4 Verarbeitungs- und Zugriffsgrenzen	5
4.1 Air-Gap-Szenario	5
4.2 Cloud-Szenario	6
4.3 Anmeldung und Administration	7
4.4 Agentenaktionen und interne Verarbeitung	7
5 Modelle und Dokumentkontext	7
5.1 Modellbereitstellung	7
5.2 Dokumentauswahl und Aufbereitung	7
6 Einstufung und Verwendung von Informationen	8
7 Aufgaben und Nutzerbelehrung	8
8 Risikoanalyse	8
8.1 Bewertungsverfahren	8
8.2 Risikomatrix	9
8.3 Risikoregister	9
9 Sicherheitsmaßnahmen	14
9.1 Geltungsbereich	14
9.2 Sicherheitsorganisation	15
9.3 Verarbeitungsfreigaben	15
9.4 Risikomanagement	16
9.5 Systemarchitektur	17
9.6 Identitäts- und Berechtigungsmanagement	17
9.7 Modellzugriffe	18
9.8 Modellverwaltung	18
9.9 Ausschluss von Modelltraining	19
9.10 Dokumentenverarbeitung	20
9.11 Agentische Anwendungen	21
9.12 Schutz vor eingeschleusten Anweisungen	22
9.13 Ergebnisprüfung	22
9.14 Werkzeugausführung	23
9.15 Ressourcenbegrenzung	24
9.16 Erprobung	24
9.17 Änderungsmanagement	24
9.18 Protokollierung	25
9.19 Betriebsüberwachung	25
9.20 Wiederherstellung	26
9.21 Außerbetriebnahme	26
9.22 Cloud-Verarbeitung und Ausweichziele	26
10 Wissenssuche	27
11 Agentische Anwendungen	28
12 Pflege der KI-Funktionen	29
12.1 Modell- und Funktionsänderungen	29
12.2 Protokolle und Auffälligkeiten	30
12.3 Wiederaufnahme und Außerbetriebnahme	30
13 BSI- und ISO-Zuordnung	30
14 Verzeichnisse	32
14.1 Quellenverzeichnis	32
14.2 Glossar und Abkürzungen	36

1 Geltungsbereich

Dieses Konzept regelt Modellverarbeitung, KI-gestützte Wissenssuche und agentische Projektarbeit. Allgemeine Infrastruktur, IT-Betrieb, Kontenverwaltung und Datenübernahme richten sich nach dem bestehenden Informationssicherheitskonzept. Die eingesetzten Programme stehen in der vorhandenen Softwareliste. Produktwahl, Hardwareumfang und Betriebsparameter sind austauschbar, solange Funktionen und Schutzgrenzen erhalten bleiben (KI-GEL-001, KI-GOV-001).

2 Nutzungskonzept

Die KI unterstützt Programmierfragen, Code- und Testfallentwürfe, Dokumentauswertung und Zusammenfassungen. Die Wissenssuche verwendet Retrieval-Augmented Generation (RAG). Agentische Funktionen bearbeiten abgegrenzte Aufträge mit den bestehenden Nutzerrechten. Training und Feinabstimmung sind ausgeschlossen. Die Arbeit bleibt ohne KI durchführbar (KI-GOV-002, KI-TRN-001).

3 Mitgeltende Vorgaben

Das Informationssicherheitskonzept und die für den jeweiligen Zweck geltenden Datenschutz-, Informationsschutz- und Freigaberegeln gelten auch für die KI-Nutzung. Dieses Dokument ergänzt ausschließlich die KI-spezifischen Aspekte. Allgemeine Anbieter- und Cloud-Betriebsregeln verbleiben in den bestehenden Verfahren (KI-GEL-001, KI-REC-001). [3] S. 69–74, 154–156

4 Verarbeitungs- und Zugriffsgrenzen

4.1 Air-Gap-Szenario

Chat, Projektassistent, Modelle und Dokumentaufbereitung befinden sich in der abgeschlossenen Umgebung. Es besteht keine Netzwerkverbindung zum Internet oder zu externen KI-Diensten. Die Übernahme benötigter Dateien erfolgt nach dem bestehenden Verfahren. Das Konzept ergänzt dieses um Modellprüfung und KI-bezogene Dokumentaufbereitung (KI-ARC-002, KI-MOD-001).

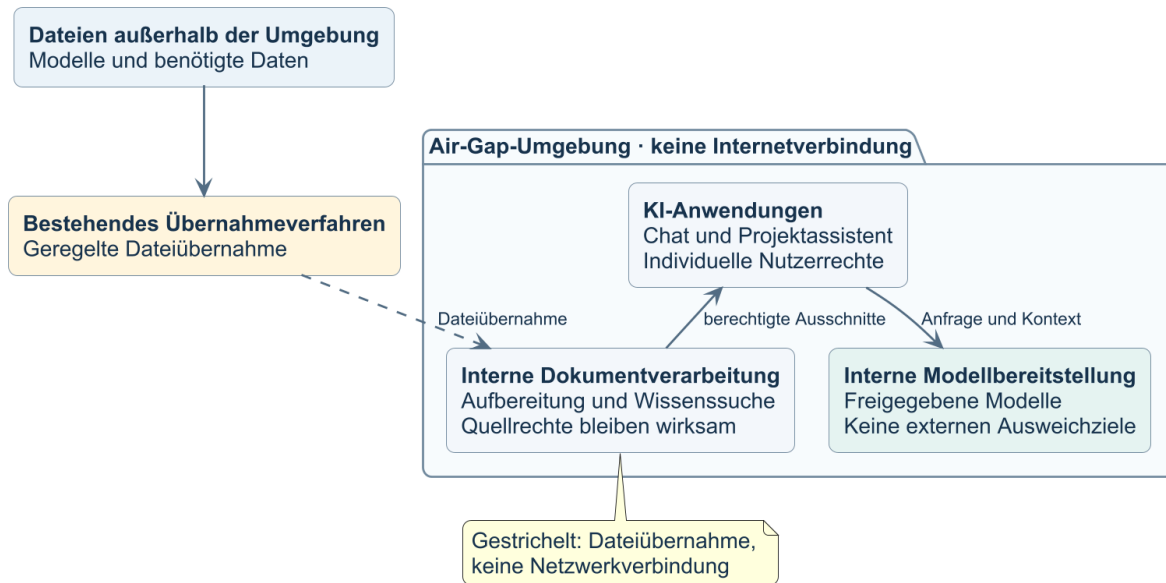


Abbildung 2: Air-Gap-Verarbeitung ohne Verbindung zu externen KI-Diensten.

4.2 Cloud-Szenario

Chatanwendung und Projektassistent verwenden den betrieblich freigegebenen Modellzugang. Dokumentenablage, Dokumentenaufbereitung, Suchvektoren und Rechteprüfung bleiben intern. Der Zugang übermittelt nur ausgewählte Eingaben und berechtigte Kontextausschnitte an den zugelassenen Anbieter. Die Freigabe erfasst auch automatisch erzeugte Folgeanfragen und Werkzeugrückmeldungen (KI-ARC-002, KI-API-002, KI-EXT-001).

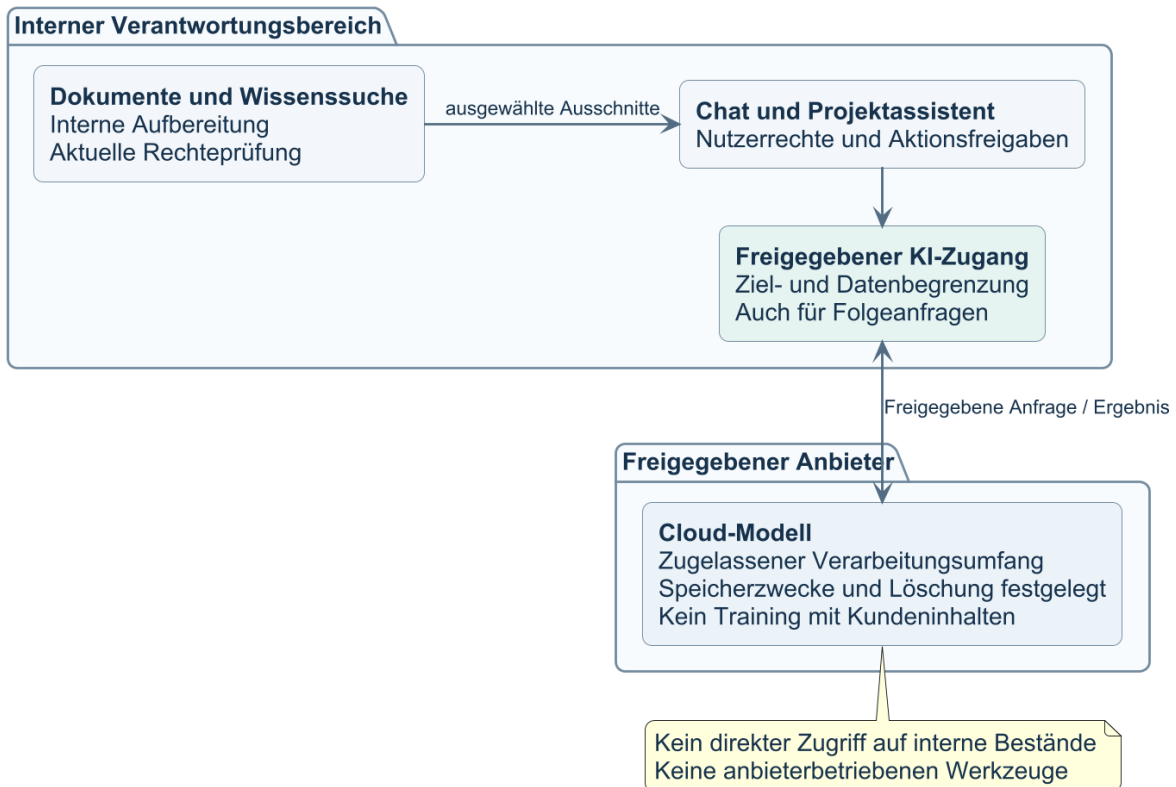


Abbildung 3: Cloud-Inferenz mit begrenzter Übermittlung und intern geprüften Datenrechten.

Das Cloud-Szenario umfasst keine anbieterbetriebenen Werkzeuge, keine externe Dokumentaufbereitung und keine Verarbeitung von Verschlusssachen. Änderungen an diesem Umfang werden vor ihrer Nutzung nach KI-VAL-002 bewertet. Ein Wechsel zwischen Air-Gap und Cloud erfolgt nicht automatisch (KI-EXT-001, KI-EXT-002).

4.3 Anmeldung und Administration

Die Chatanwendung nutzt die betriebliche Identitätsverwaltung. Der Projektassistent arbeitet in der regulären Nutzersitzung. Die Administration verwaltet Modelle, serverseitige Werkzeuge und Aufgabenprofile. Technische Dienstzugänge ersetzen keine Prüfung individueller Nutzerrechte (KI-API-001, KI-IAM-001).

4.4 Agentenaktionen und interne Verarbeitung

Genehmigte Datei- und Befehlsaktionen des Projektassistenten laufen mit den bestehenden Nutzerrechten. Ein interner Ausführungsdienst der Chatanwendung ist ausschließlich für deren Verarbeitung erreichbar. Er stellt keinen eigenen serverseitigen Codeausführungszugang für Nutzende bereit (KI-AGT-001, KI-TOL-002).

5 Modelle und Dokumentkontext

5.1 Modellbereitstellung

Lokale Modelle werden auf Herkunft, Integrität und Ladeformat geprüft. Cloud-Modelle werden über den freigegebenen Zugang mit zulässigen Testdaten erprobt. Änderungen an Modellen, Aufgabenprofilen oder verfügbaren Funktionen unterliegen der Änderungsprüfung (KI-MOD-001, KI-MOD-002, KI-VAL-001).

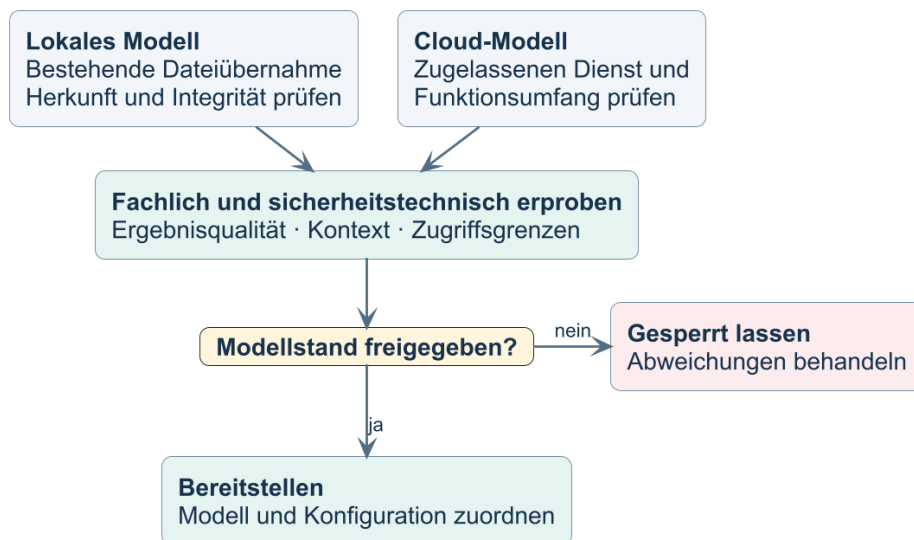


Abbildung 4: Modellprüfung und Freigabe entsprechend dem Betriebsweg.

5.2 Dokumentauswahl und Aufbereitung

Fach- und Datenverantwortliche legen je Anwendungsfall zulässige und ausgeschlossene Datenarten fest. Nutzende wählen daraus die für ihren Auftrag erforderlichen Dokumente innerhalb ihrer Befug-

nisse aus. Vor Aufnahme und danach regelmäßig werden Herkunft, Vertrauenswürdigkeit, fachliche Eignung, Aktualität, Vollständigkeit sowie Nutzungs- und Verarbeitungsrechte geprüft. Dokumente unbekannter oder nicht vertrauenswürdiger Herkunft werden nicht aufgenommen. Die interne Aufbereitung verwendet bei Bedarf Optical Character Recognition (OCR), führt Quellrechte fort und stellt nur berechnete Ausschnitte bereit. Die zusätzliche Cloud-Freigabe gilt für alle übermittelten Inhalte, auch wenn sie automatisch aus Dateien oder Werkzeugantworten ergänzt werden (KI-RAG-001 bis KI-RAG-004, KI-EXT-001).

6 Einstufung und Verwendung von Informationen

Die erstellende Person legt die Einstufung eigener Informationen im Rahmen ihrer Befugnisse fest. Vorgegebene Einstufungen verwendeter Quellen bleiben erhalten. Bei Ergebnissen wird auch der Schutzbedarf zusammengeführter Informationen berücksichtigt. Die Entscheidung über Verarbeitung und Weitergabe bleibt an Zweck, berechtigten Empfängerkreis und den zugelassenen Verarbeitungsumfang gebunden (KI-REC-001, KI-REC-002).

7 Aufgaben und Nutzerbelehrung

Die KI-Verantwortlichen steuern die zugelassenen KI-Funktionen. Fach- und Datenverantwortliche legen Anwendungsfälle und Datenarten fest. Die Administration stellt die freigegebenen Funktionen bereit. Testverantwortliche planen Prüfungen, dokumentieren die tatsächlich ausgeführten Schritte und bewerten Ergebnisse gemeinsam mit den Fachverantwortlichen. Änderungsverantwortliche entscheiden über den erforderlichen Prüfumfang. Betriebsverantwortliche behandeln Störungen und Außerbetriebnahmen. Nutzende bestimmen innerhalb der Freigaben Inhalte, Auftrag und Aktionsumfang und prüfen Ergebnisse vor ihrer Verwendung. Die Informationssicherheitsverantwortlichen bewerten die KI-spezifischen Risiken im bestehenden Zuständigkeitsrahmen (KI-GOV-001 bis KI-GOV-003).

Die Belehrung erfolgt anhand der Anlage 1. Die Unterschrift bestätigt ausschließlich Teilnahme, Verständnis und persönliche Verpflichtung zur Einhaltung der Regeln. Sie ersetzt weder technische Prüfungen noch die fachliche Freigabe oder den Nachweis der betrieblichen Wirksamkeit. Die Belehrung umfasst Datenauswahl, Einstufung, Ergebnisprüfung und Agentenaktionen. Bei Cloud-Nutzung behandelt sie zusätzlich den zulässigen Umfang der Übermittlung an den Anbieter (KI-GOV-002).

8 Risikoanalyse

8.1 Bewertungsverfahren

Die Risikoanalyse bewertet neun KI-spezifische Szenarien für Air-Gap- und Cloud-Nutzung getrennt. Die Ausgangsbewertung berücksichtigt die allgemeinen IT-Schutzmaßnahmen, die Restbewertung zusätzlich die zugeordneten KI-Kontrollen. Die Werte gelten für die beschriebenen Referenzszenarien. Selten bedeutet weniger als einmal in fünf Jahren, mittel einmal in fünf Jahren bis einmal jährlich, häufig mehr als einmal jährlich bis einmal monatlich und sehr häufig mehr als einmal monatlich. Bewertet wird das schädliche Ereignis. Vernachlässigbarer Schaden hat kaum betriebliche Folgen. Begrenzter Schaden verursacht beherrschbare Mehrarbeit. Beträchtlicher Schaden umfasst erhebliche Daten-, Qualitäts- oder Betriebsfolgen. Existenzbedrohender Schaden gefährdet den Fortbestand.

Die Risikoakzeptanz erfolgt im bestehenden Zuständigkeitsrahmen anhand des tatsächlichen Verarbeitungsumfangs. [4] S. 26–28, 33–35

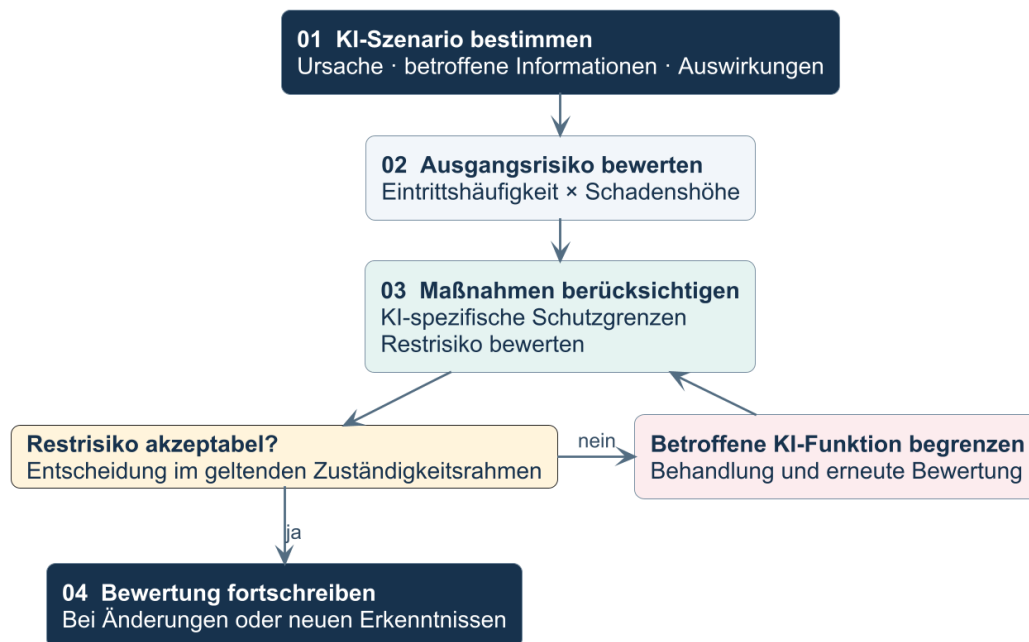


Abbildung 5: Szenariobezogene Bewertung und Behandlung der KI-Risiken.

8.2 Risikomatrix

Schadenshöhe / Eintrittshäufigkeit	selten	mittel	häufig	sehr häufig
existenzbedrohend	mittel	hoch	sehr hoch	sehr hoch
beträchtlich	mittel	mittel	hoch	sehr hoch
begrenzt	gering	gering	mittel	hoch
vernachlässigbar	gering	gering	gering	gering

Gemeinsamer Maßstab nach BSI-Standard 200-3
Air-Gap und Cloud: Einzelbewertungen im Risikoregister

Abbildung 6: Gemeinsamer Bewertungsmaßstab für beide Szenarien.

8.3 Risikoregister

R-01

Eine eingeschleuste Anweisung führt zu einer Aktion außerhalb des erteilten Auftrags.

Szenario	Ausgangsrisiko	Restrisiko
Air-Gap	häufig × beträchtlich = hoch	selten × beträchtlich = mittel

Szenario	Ausgangsrisiko	Restrisiko
Cloud	häufig × beträchtlich = hoch	selten × beträchtlich = mittel

Auftragsgrenzen, unabhängige Rechteprüfung und konkrete Aktionsgenehmigungen begrenzen Werkzeugaktionen.

Die Ausgangsbewertung erfasst den beschriebenen Ablauf vor den zusätzlichen KI-Kontrollen. Agentische Aktionen bleiben auf die regulären Nutzerrechte beschränkt. Verbindliche Ergebnisse werden durch die befugte Person übernommen.

Die zusätzlichen KI-Kontrollen senken die Häufigkeit des schädlichen Ereignisses. Die mögliche Schadenshöhe bleibt bei beträchtlich und führt zum Restrisiko mittel.

Cloud: Auch im Cloud-Szenario werden Aktionen lokal genehmigt und ausgeführt. Ein Modellvorschlag erteilt keine Berechtigung.

Zugeordnete Maßnahmen: KI-PMT-001, KI-TOL-001, KI-AGT-001, KI-THR-001.

R-02

Ein ungeeigneter oder veränderter Modellstand beeinflusst Ergebnisse oder Werkzeugvorschläge.

Szenario	Ausgangsrisiko	Restrisiko
Air-Gap	mittel × beträchtlich = mittel	selten × beträchtlich = mittel
Cloud	mittel × beträchtlich = mittel	selten × beträchtlich = mittel

Modellprüfung, Erprobung und Änderungsprüfung begrenzen die Verwendung ungeprüfter Funktionen.

Die Ausgangsbewertung erfasst den beschriebenen Ablauf vor den zusätzlichen KI-Kontrollen. Lokale Modellstände werden kontrolliert bereitgestellt. Die Auswirkungen eines fehlerhaften Modells können mehrere Arbeitsvorgänge betreffen.

Die zusätzlichen KI-Kontrollen senken die Häufigkeit des schädlichen Ereignisses. Die mögliche Schadenshöhe bleibt bei beträchtlich und führt zum Restrisiko mittel.

Cloud: Anbieteränderungen können auch unter gleicher Kennung auftreten. Regelmäßige Verhaltensprüfung und Unterbrechung bei ungeklärten Änderungen begrenzen die Nutzung.

Zugeordnete Maßnahmen: KI-MOD-001, KI-TOL-002, KI-VAL-002.

R-03

Ein Suchtreffer oder eine Zusammenfassung enthält Informationen für unberechtigte Personen.

Szenario	Ausgangsrisiko	Restrisiko
Air-Gap	häufig × beträchtlich = hoch	selten × beträchtlich = mittel
Cloud	häufig × beträchtlich = hoch	selten × beträchtlich = mittel

Rechteprüfung vor der Kontextbildung, getrennte persönliche Inhalte und geregelte Freigaben begrenzen den Empfängerkreis.

Die Ausgangsbewertung erfasst den beschriebenen Ablauf vor den zusätzlichen KI-Kontrollen. Quellrechte werden außerhalb des Modells durchgesetzt. Eine fehlerhafte Rechtezuordnung kann dennoch erhebliche Folgen haben.

Die zusätzlichen KI-Kontrollen senken die Häufigkeit des schädlichen Ereignisses. Die mögliche Schadenshöhe bleibt bei beträchtlich und führt zum Restrisiko mittel.

Cloud: Die interne Berechtigungsprüfung erfolgt vor der Übermittlung an das Cloud-Modell. Zusätzlich muss der ausgewählte Kontext für den Anbieter freigegeben sein.

Zugeordnete Maßnahmen: KI-RAG-002, KI-RAG-003, KI-RAG-004, KI-REC-001.

R-04

Ein Modellzugriff umgeht die vorgesehenen Nutzer- oder Funktionsrechte.

Szenario	Ausgangsrisiko	Restrisiko
Air-Gap	mittel × beträchtlich = mittel	selten × beträchtlich = mittel
Cloud	mittel × beträchtlich = mittel	selten × beträchtlich = mittel

Zentrale Anmeldung, individuelle Rechte und begrenzte Modellrouten gelten auch für direkte Schnittstellenaufrufe.

Die Ausgangsbewertung erfasst den beschriebenen Ablauf vor den zusätzlichen KI-Kontrollen. Die Zugriffskontrolle wird unabhängig vom Modell geprüft. Fehler an Identitätsbindungen können geschützte Funktionen betreffen.

Die zusätzlichen KI-Kontrollen senken die Häufigkeit des schädlichen Ereignisses. Die mögliche Schadenshöhe bleibt bei beträchtlich und führt zum Restrisiko mittel.

Cloud: Technische Anbieterzugänge sind an den betrieblichen KI-Zugang gebunden. Ein gemeinsamer Dienstschlüssel ersetzt keine Nutzerprüfung.

Zugeordnete Maßnahmen: KI-API-001, KI-IAM-001.

R-05

Gesprächs- oder Dokumentinhalte bleiben in Protokollen oder Kontextkopien unzulässig verfügbar.

Szenario	Ausgangsrisiko	Restrisiko
Air-Gap	häufig × beträchtlich = hoch	selten × beträchtlich = mittel
Cloud	häufig × beträchtlich = hoch	selten × beträchtlich = mittel

Datensparsame Protokollierung, begrenzte Speicherung und wirksame Sperr- und Löschwege erfassen auch KI-Ableitungen.

Die Ausgangsbewertung erfasst den beschriebenen Ablauf vor den zusätzlichen KI-Kontrollen. Die reguläre Protokollierung erfasst keine vollständigen Gesprächsinhalte. Unbeabsichtigte Inhaltsübernahme bleibt als Fehlerszenario berücksichtigt.

Die zusätzlichen KI-Kontrollen senken die Häufigkeit des schädlichen Ereignisses. Die mögliche Schadenshöhe bleibt bei beträchtlich und führt zum Restrisiko mittel.

Cloud: Aufbewahrung und Missbrauchsprüfung beim Anbieter sind Teil der Freigabe. Eine Übermittlung kann durch spätere lokale Löschung nicht rückgängig gemacht werden.

Zugeordnete Maßnahmen: KI-OPS-001, KI-RAG-004, KI-REC-002.

R-06

Überlange Anfragen oder Agentenschleifen beeinträchtigen die verfügbare KI-Kapazität.

Szenario	Ausgangsrisiko	Restrisiko
Air-Gap	häufig × begrenzt = mittel	selten × begrenzt = gering
Cloud	häufig × begrenzt = mittel	selten × begrenzt = gering

Kontext-, Laufzeit- und Auftragsgrenzen begrenzen Ressourcenverbrauch. Die Arbeit bleibt ohne KI durchführbar.

Die Ausgangsbewertung erfasst den beschriebenen Ablauf vor den zusätzlichen KI-Kontrollen. Die Auswirkungen betreffen zusätzliche Bearbeitungszeit. Die KI ist kein alleiniger Zugang zu unverzichtbaren Arbeitsfunktionen.

Die zusätzlichen KI-Kontrollen senken die Häufigkeit des schädlichen Ereignisses. Die mögliche Schadenshöhe bleibt bei begrenzt und führt zum Restrisiko gering.

Cloud: Zusätzlich sind Kosten- und Verbrauchsgrenzen für den Cloud-Dienst wirksam. Anbieterunterbrechungen führen zur Weiterarbeit ohne KI.

Zugeordnete Maßnahmen: KI-GOV-002, KI-THR-002, KI-OPS-003.

R-07

Ein fehlerhaftes KI-Ergebnis wird fachlich übernommen und verursacht eine falsche Entscheidung.

Szenario	Ausgangsrisiko	Restrisiko
Air-Gap	häufig × beträchtlich = hoch	selten × beträchtlich = mittel
Cloud	häufig × beträchtlich = hoch	selten × beträchtlich = mittel

Fachliche Ergebnisprüfung und bestehende Qualitätsverfahren gelten auch für KI-Ergebnisse und generierten Code.

Die Ausgangsbewertung erfasst den beschriebenen Ablauf vor den zusätzlichen KI-Kontrollen. KI unterstützt die Bearbeitung. Die befugte Person entscheidet über die Verwendung. Übersehene Fehler können trotz Prüfung erheblich schaden.

Die zusätzlichen KI-Kontrollen senken die Häufigkeit des schädlichen Ereignisses. Die mögliche Schadenshöhe bleibt bei beträchtlich und führt zum Restrisiko mittel.

Cloud: Die Herkunft aus einem Cloud-Modell ersetzt keine fachliche Prüfung. Anbieterwechsel und veränderte Modellausgaben werden bei der Erprobung berücksichtigt.

Zugeordnete Maßnahmen: KI-OUT-001, KI-VAL-001, KI-TOL-001.

R-08

Ein nicht freigegebener Modellpfad verarbeitet Inhalte außerhalb des zulässigen Umfangs oder verwendet sie für Training.

Szenario	Ausgangsrisiko	Restrisiko
Air-Gap	mittel × begrenzt = gering	selten × begrenzt = gering
Cloud	mittel × beträchtlich = mittel	selten × beträchtlich = mittel

Zielbegrenzung und Trainingsausschluss gelten für direkte Anfragen, Erweiterungen, Folgeaufrufe und Ausweichziele.

Die Ausgangsbewertung erfasst den beschriebenen Ablauf vor den zusätzlichen KI-Kontrollen. In der Air-Gap-Umgebung besteht keine Netzwerkverbindung zu externen Modellzielen. Bewertet bleiben lokale unzulässige Modell- oder Trainingsfunktionen.

Die zusätzlichen KI-Kontrollen senken die Häufigkeit des schädlichen Ereignisses. Die mögliche Schadenshöhe bleibt bei begrenzt und führt zum Restrisiko gering.

Cloud: Die Freigabe umfasst Anbieter, Verarbeitungsorte, Speicherzwecke und Ausschluss von Anbietertraining. Fehlerhafte Übermittlung oder eine abweichende Anbieterbehandlung können erhebliche Folgen haben.

Zugeordnete Maßnahmen: KI-ARC-002, KI-EXT-001, KI-EXT-002, KI-TRN-001.

R-09

Ein Modell- oder Aufbereitungswechsel führt zu inkonsistenten Suchbeständen und fehlerhaftem Kontext.

Szenario	Ausgangsrisiko	Restrisiko
Air-Gap	mittel × begrenzt = gering	selten × begrenzt = gering
Cloud	mittel × begrenzt = gering	selten × begrenzt = gering

Änderungsprüfung und konsistente Zuordnung von Modellen und Indizes begrenzen unpassende Suchergebnisse.

Die Ausgangsbewertung erfasst den beschriebenen Ablauf vor den zusätzlichen KI-Kontrollen. Die betroffene Wissensuche wird bei Inkonsistenz gesperrt oder neu aufgebaut. Fachliche Ergebnisse werden unabhängig geprüft.

Die zusätzlichen KI-Kontrollen senken die Häufigkeit des schädlichen Ereignisses. Die mögliche Schadenshöhe bleibt bei begrenzt und führt zum Restrisiko gering.

Cloud: Cloud-Modellwechsel werden auf ihre Wirkung auf bestehende Aufgabenprofile und die interne Kontextbereitstellung geprüft.

Zugeordnete Maßnahmen: KI-MOD-002, KI-VAL-001, KI-VAL-002, KI-OPS-003.

9 Sicherheitsmaßnahmen

Die folgenden Kontrollen beschreiben die KI-Sicherheitsmaßnahmen der beiden Referenzszenarien. Die Aufgaben sind in Kapitel 7 zugeordnet. Die Risikobewertung folgt KI-GOV-003.

9.1 Geltungsbereich

KI-GEL-001 – KI-spezifische Ergänzung des Informationssicherheitskonzepts

Geltung: Beide Szenarien

Festlegung

Dieses Konzept ergänzt das bestehende Informationssicherheitskonzept um die Anforderungen aus Modellverarbeitung, KI-gestützter Wissenssuche und agentischer Projektarbeit. Es umfasst ein Air-Gap-Szenario und ein Cloud-Szenario. Die allgemeinen Bestimmungen zu Infrastruktur, IT-Betrieb, Datenübernahme und Informationsschutz gelten für beide Szenarien.

Betrieb und Anwendung

Die KI-Nutzung ist in die bestehenden Zuständigkeiten und Freigabeverfahren eingebunden. Die gemeinsamen Kontrollen gelten in beiden Szenarien. Szenariospezifische Festlegungen bestimmen den Modellstandort, die zulässigen Datenwege und die Freigabe externer Verarbeitung. Allgemeine Infrastruktur- und Cloud-Betriebsregeln werden im bestehenden Informationssicherheitskonzept geführt.

Quellen: [2] S. 4–5 und S. 11–12 · [3] S. 11, S. 69–74 und S. 154–156 · [33]

KI-GEL-002 – Schutzkennzeichnung und kontrollierte Dokumentenführung

Geltung: Beide Szenarien

Festlegung

Die allgemeine Referenzfassung ist öffentlich. Eine betriebliche Konzeptfassung trägt die ihrer tatsächlichen Inhalte entsprechende Schutzkennzeichnung und ist nur für den zugelassenen Empfängerkreis verfügbar.

Betrieb und Anwendung

Dokumenttitel, Version, Dokumentdatum und fortlaufende Seitenzählung kennzeichnen die Fassung. Für Ablage, Verteilung und ersetzte Fassungen gelten die bestehenden Regeln der Dokumentenlenkung. Der öffentliche Status der Referenz gilt nicht automatisch für betriebliche Angaben.

Quellen: [31] § 4 · [32] · [1] S. 26–27

9.2 Sicherheitsorganisation

KI-GOV-001 – KI-Funktionen und Softwarezuordnung

Geltung: Beide Szenarien

Festlegung

Für jede KI-Funktion sind Zweck, zugelassene Anwendungsfälle und Datenarten, verantwortliche Rollen sowie Modell-, Werkzeug- und Datengrenzen festgelegt. Die eingesetzten Programme, Modellstände und Aufgabenprofile sind diesen Funktionen in der vorhandenen Softwareliste und den Dienstkonfigurationen zugeordnet. Produktwahl, Hardwareumfang und technische Betriebsparameter bleiben austauschbar, solange die festgelegten Funktionen und Schutzgrenzen erhalten bleiben.

Betrieb und Anwendung

Die Funktionszuordnung umfasst Chatanwendung, agentischen Projektassistenten, Modellbereitstellung, Dokumentaufbereitung und Wissensuche. Für Betrieb und Administration, Datenauswahl, fachliche Prüfung, Änderungsentscheidung, Vorfallbehandlung und Löschung sind zuständige Rollen benannt. Im Cloud-Szenario ist auch der zugelassene Dienst mit seinem Verarbeitungsumfang zugeordnet. Änderungen folgen KI-VAL-002.

Quellen: [2] S. 8–10 · [5] S. 24–28 · [8] Art. 9 und 26

KI-GOV-002 – KI-Nutzung und Nutzerbelehrung

Geltung: Beide Szenarien

Festlegung

Die KI unterstützt betriebliche Aufgaben. Nutzende bestimmen den Arbeitsauftrag, wählen die zulässigen Inhalte aus und prüfen die Ergebnisse vor ihrer Verwendung. Die Nutzerbelehrung erfolgt anhand der Anlage 1. Mit ihrer Unterschrift bestätigen die Nutzenden ausschließlich die Teilnahme, ihr Verständnis und ihre persönliche Verpflichtung zur Einhaltung der Nutzungsregeln.

Betrieb und Anwendung

Die Belehrung behandelt Datenauswahl, Einstufung, Ergebnisprüfung und Agentenfreigaben. Für Cloud-Nutzung umfasst sie zusätzlich die zulässige Übermittlung von Eingaben und Kontext an den freigegebenen Anbieter. Die Bestätigung der Belehrung ersetzt weder technische Prüfungen noch die fachliche Freigabe oder den Nachweis der betrieblichen Wirksamkeit. Sie ergänzt die geltenden Unterweisungen zu Informationsschutz und Datenschutz. Die betrieblichen Aufgaben bleiben auch ohne KI durchführbar.

Quellen: [2] S. 8–10 und S. 13 · [1] S. 29–30 · [8] Art. 4

9.3 Verarbeitungsfreigaben

KI-REC-001 – Zulässige Inhalte im Modellkontext

Geltung: Beide Szenarien

Festlegung

Für jeden freigegebenen Anwendungsfall sind zulässige und ausgeschlossene Datenarten sowie der erlaubte Verarbeitungsumfang festgelegt. Nutzende wählen daraus die für ihren betrieblichen Auftrag erforderlichen Inhalte aus und prüfen vor der Eingabe, ob die Verarbeitung für diesen Zweck und innerhalb ihrer Befugnisse zulässig ist. Dies gilt auch für Dokumente, Gesprächsverläufe und automatisch einbezogenen Projektkontext.

Betrieb und Anwendung

Fach- und Datenverantwortliche legen die zulässigen und ausgeschlossenen Datenarten je Anwendungsfall und Szenario fest. Personenbezogene Daten werden nur im zulässigen und erforderlichen Umfang einbezogen. Nutzende berücksichtigen bei der Auswahl auch enthaltene Informationen Dritter. Die Zugriffsberechtigung auf eine Datei allein begründet keine weitergehende Verwendungsbefugnis. Für eine Weitergabe entscheiden sie über Inhalt und Empfängerkreis im Rahmen der geltenden Bestimmungen. Anlage 1 enthält die zugehörigen Nutzungsregeln.

Quellen: [2] S. 8–10 · [8] Art. 2–4, 26–27 · [9] · [10]

KI-REC-002 – Einstufung und Freigabe von KI-Inhalten**Geltung: Beide Szenarien****Festlegung**

Die erstellende Person legt die Einstufung der von ihr erzeugten Informationen im Rahmen ihrer Befugnisse und der geltenden Bestimmungen fest. Sie entscheidet entsprechend über deren KI-Verarbeitung und Freigabe zur Weitergabe. Der zugelassene Verarbeitungsumfang der Umgebung bleibt maßgeblich.

Betrieb und Anwendung

Vorgegebene Einstufungen verwendeter Quellen bleiben erhalten. Bei KI-Ergebnissen berücksichtigt die erstellende Person auch den Schutzbedarf der darin zusammengeführten Informationen. Eine abweichende oder aufgehobene Einstufung setzt die entsprechende Befugnis voraus. Die Nutzerbelehrung nach Anlage 1 umfasst diese Pflichten. Eine KI-Ausgabe erteilt keine Verarbeitungs- oder Weitergabefreigabe.

Quellen: [1] S. 25–27 · [31] § 4 · [32] · [12]

9.4 Risikomanagement**KI-GOV-003 – Bewertung KI-spezifischer Risiken****Geltung: Beide Szenarien****Festlegung**

Die Risikobewertung erfasst die zusätzlichen Risiken der KI-Nutzung und die in diesem Konzept beschriebenen Schutzmaßnahmen. Der Informationssicherheitsbeauftragte bewertet sie mit den fachlich zuständigen Personen. Die Entscheidung über die Akzeptanz verbleibender Risiken erfolgt im geltenden Zuständigkeitsrahmen.

Betrieb und Anwendung

Bei Änderungen an KI-Funktionen, Datenverwendung oder Berechtigungsgrenzen wird die betroffene Bewertung überprüft. Erkenntnisse aus der Nutzung und aus Sicherheitsprüfungen fließen ein. Nicht akzeptable Risiken erfordern eine Begrenzung oder Unterbrechung der betroffenen KI-Funktion bis zur Entscheidung über die weitere Nutzung.

Quellen: [2] S. 8, 10 und 12 · [4] S. 5–7, S. 26–28 und S. 33–35 · [5] S. 24–25 und S. 45–47 · [13]

KI-THR-001 – Prüfung KI-spezifischer Fehl- und Missbrauchsszenarien

Geltung: Beide Szenarien

Festlegung

Die Sicherheitsprüfung umfasst eingeschleuste Anweisungen, unzulässige Modell- und Werkzeugzugriffe, fehlerhafte Zuordnung von Suchinhalten sowie die Überschreitung des erteilten Agentenauftrags. Die Berechtigungsprüfung erfolgt unabhängig vom Sprachmodell.

Betrieb und Anwendung

Geprüft werden repräsentative Eingaben, Projektdateien, Dokumente und Werkzeugantworten. Direkte Schnittstellenzugriffe, Rechteentzug, Nutzertrennung und Änderungen am Modellkontext werden einbezogen. Festgestellte Abweichungen werden vor der Freigabe der betroffenen Funktion behoben oder durch eine wirksame Begrenzung behandelt.

Quellen: [2] S. 12–16 · [4] S. 5–7, S. 26–28 und S. 33–35 · [14] · [18] · [17]

9.5 Systemarchitektur

KI-ARC-002 – Verarbeitungsgrenzen der Szenarien

Geltung: Beide Szenarien

Festlegung

Im Air-Gap-Szenario werden Modelle, Dokumentaufbereitung und Wissenssuche innerhalb einer vom Internet getrennten Umgebung betrieben. Es besteht keine Netzwerkverbindung zu externen KI-Diensten. Im Cloud-Szenario erfolgt die Modellverarbeitung beim dafür freigegebenen Anbieter. Der Zugang übermittelt ausschließlich die für diesen Dienst zugelassenen Inhalte.

Betrieb und Anwendung

Für die Dateiübernahme in die Air-Gap-Umgebung gilt das bestehende Übernahmeverfahren. Die KI-Ergänzungen betreffen Modellprüfung und Dokumentaufbereitung. Im Cloud-Szenario bleiben die Dokumentablage, Berechtigungsprüfung und Auswahl von Suchtreffern intern. Nur ausgewählte Eingaben und berechtigte Kontextausschnitte werden an den freigegebenen Modellendpunkt übermittelt. Externe Dokumentaufbereitung, externe Suchvektorerzeugung und anbieterbetriebene Werkzeuge sind von diesem Szenario nicht umfasst. Für externe Inferenz gilt zusätzlich KI-EXT-001.

Quellen: [2] S. 9–12 · [1] S. 25–28 · [16]

9.6 Identitäts- und Berechtigungsmanagement

KI-API-001 – Anmeldung und KI-Zugriffsrechte

Geltung: Beide Szenarien

Festlegung

Die Chatanwendung verwendet die betriebliche Identitätsverwaltung. Der agentische Projektassistent arbeitet in der regulären Sitzung der angemeldeten Person. Modell- und Datenzugriffe sind auf die freigegebenen KI-Funktionen und die individuellen Berechtigungen begrenzt.

Betrieb und Anwendung

Anwendungsrechte gelten auch bei direkten Aufrufen der Programmierschnittstelle (API). Gesperrte oder entzogene Rechte werden wirksam durchgesetzt. Technische Zugangsdaten für Modellend-

punkte ersetzen keine personenbezogene Berechtigungsprüfung. Die KI-Nutzung erweitert die bestehenden Rechte nicht.

Quellen: [22] · [23] · [25] · [2] S. 12

KI-IAM-001 – Berechtigungen für KI-Nutzung und KI-Verwaltung

Geltung: Beide Szenarien

Festlegung

Nutzende verwenden die freigegebenen Chat- und Agentenfunktionen. Modelle, serverseitige Werkzeuge, Aufgabenprofile und KI-Betriebseinstellungen werden ausschließlich durch die Administration eingerichtet und geändert. Zugangsdaten und andere Geheimnisse werden nicht in den Modellkontext aufgenommen.

Betrieb und Anwendung

Nutzende prüfen auch bereitgestellte Dateien und automatisch einbezogenen Projektkontext auf Zugangsdaten. Lokale Projektregeln erteilen keine Berechtigung zur Verwaltung von KI-Serverfunktionen. Für allgemeine Konten- und Rechteverwaltung gilt KI-GEL-001.

Quellen: [2] S. 8–13 · [1] S. 25–29 · [11]

9.7 Modellzugriffe

KI-API-002 – Serverseitige Grenzen für Modellzugriffe

Geltung: Beide Szenarien

Festlegung

Die Grenzen für Modelle, Datenkontexte, Werkzeuge und Anfragen werden außerhalb des Sprachmodells durchgesetzt. Vorbereitete Aufgabenprofile bündeln freigegebene Vorgaben und Fähigkeiten. Direkte Schnittstellenaufrufe und veränderte Parameter erlauben keine Umgehung der Zugriffsgrenzen.

Betrieb und Anwendung

Die Administration verwaltet Modellzuordnung und Aufgabenprofile. Hauptmodell, Dokumentaufbereitung und Suchvektorerzeugung haben getrennte Zwecke und Rechte. Nur benötigte Modellfunktionen sind erreichbar. Die Prüfung umfasst unzulässige Modellkennungen, erweiterte Werkzeuge und Diagnoserouten. Im Cloud-Szenario ist die Ziel- und Datenfreigabe auch vor automatisch erzeugten Folgeanfragen und Werkzeugrückmeldungen wirksam.

Quellen: [2] S. 11–16 · [23] · [17]

9.8 Modellverwaltung

KI-MOD-001 – Prüfung bereitgestellter Modelle

Geltung: Beide Szenarien

Festlegung

Die Administration prüft lokal bereitgestellte Modelle auf Herkunft, Integrität und Ladeformat. Ausführbare Begleitbestandteile werden einbezogen. Ungeprüfter Begleitcode wird nicht automatisch ausgeführt. Bei Cloud-Modellen werden der freigegebene Dienst, die verfügbare Modellkennung und die angebotenen Funktionen geprüft.

Betrieb und Anwendung

Lokale Modellartefakte durchlaufen das bestehende Übernahmeverfahren und die KI-Erprobung nach KI-VAL-001. Für Cloud-Modelle erfolgt die Erprobung über den zugelassenen Zugang mit dafür freigegebenen Testdaten. Ein ungeprüfter Modellwechsel erweitert weder den Verarbeitungsumfang noch die verfügbaren Werkzeuge.

Quellen: [2] S. 9–10 · [16] · [17]

KI-MOD-002 – Austauschbare Modellstände mit stabilen Modellaliasen**Geltung: Beide Szenarien****Festlegung**

Modelle, Laufzeiten und Konfigurationen sind einem freigegebenen Betriebsstand zugeordnet. Stabile Modellaliasen werden verwendet, soweit die Schnittstelle sie unterstützt. Ein Wechsel unter unveränderter Kennung wird nach KI-VAL-002 geprüft.

Betrieb und Anwendung

Bei lokalem Betrieb verbindet die Dienstkonfiguration den Alias mit Modellartefakt und Laufzeit. Im Cloud-Szenario werden die verfügbare Modellversion und Änderungen des Anbieters berücksichtigt. Ist eine feste Version nicht verfügbar, wird das Modellverhalten regelmäßig und bei erkennbaren Änderungen überprüft. Bei ungeklärter Abweichung wird die betroffene Nutzung begrenzt oder unterbrochen. Änderungen am Embedding-Modell berücksichtigen die Konsistenz der Suchindizes.

Quellen: [2] S. 9–12 · [5] S. 25–32 · [38]

9.9 Ausschluss von Modelltraining**KI-TRN-001 – Keine Änderung von Modellgewichten****Geltung: Beide Szenarien****Festlegung**

Die Nutzung umfasst ausschließlich Inferenz. Eigenes Training, Feinabstimmung und selbsttätiges Lernen aus betrieblichen Eingaben sind ausgeschlossen. Im Cloud-Szenario ist die Nutzung von Eingaben, Kontext und Ergebnissen für Anbietertraining oder Modellverbesserung ausgeschlossen.

Betrieb und Anwendung

Trainingsaufträge und Schreibzugriffe auf lokale Modellgewichte sind gesperrt. Dies umfasst Fine-Tuning, LoRA und RLHF. Systemvorgaben, Aufgabenprofile und Wissensbestände verändern keine Modellgewichte. Im Cloud-Szenario entsprechen Dienstbedingungen und wirksame Einstellungen dem Trainingsausschluss. Reguläre Modellwechsel des Anbieters werden als Änderungen nach KI-MOD-002 behandelt.

Quellen: [2] S. 5 zur Abgrenzung von Modellentwicklung und Fine-Tuning · [5] S. 25–32 zum kontrollierten Lebenszyklus · [38]

9.10 Dokumentenverarbeitung

KI-RAG-001 – Aufnahme von Dokumenten in den KI-Kontext

Geltung: Beide Szenarien

Festlegung

Nutzende wählen Dokumente aus freigegebenen Beständen innerhalb ihrer Berechtigungen und für den jeweiligen Arbeitsauftrag aus. Vor der Aufnahme und danach regelmäßig werden Herkunft, Vertrauenswürdigkeit, fachliche Eignung, Aktualität, Vollständigkeit sowie Nutzungs- und Verarbeitungsrechte durch die zuständigen Fach- und Datenverantwortlichen geprüft. Dokumente unbekannter oder nicht vertrauenswürdiger Herkunft werden nicht aufgenommen. Die Dokumentaufbereitung ist auf zulässige Formate und den erforderlichen Verarbeitungsumfang begrenzt.

Betrieb und Anwendung

Für die Wissenssuche werden ausschließlich fachlich freigegebene, hinreichend aktuelle und rechtlich nutzbare Dokumente aufbereitet. Prüfentscheidung, verantwortliche Stelle und nächster Prüftermin bleiben nachvollziehbar. Aktive Dateiinhalte werden nicht als Arbeitsauftrag ausgeführt. Extraktion, Texterkennung und Zerlegung in Textabschnitte verwenden begrenzte Rechte und Ressourcen. Fehlerhaft aufbereitete Dateien werden nicht in den Suchbestand übernommen. Quellrechte und Herkunft werden an die Ableitungen weitergegeben.

Quellen: [12] · [11] · [17]

KI-RAG-002 – Durchgängige Berechtigungsprüfung und Indextrennung

Geltung: Beide Szenarien

Festlegung

Die Berechtigungen der Quellen werden vor Aufnahme und bei jeder Abfrage durchgesetzt. Quellen und sämtliche Ableitungen werden innerhalb des zulässigen Empfängerkreises verarbeitet. Zugriffsentscheidungen erfolgen außerhalb des Sprachmodells.

Betrieb und Anwendung

Der Suchdienst filtert Treffer nach aktuellen Nutzerrechten, bevor er sie dem Modell übergibt. Quellrechte gelten auch für OCR-Texte, Textabschnitte, Suchvektoren, Indizes und Antworten. Technische Speicherrechte eines Dienstes begründen keine Nutzerfreigabe. Persönliche Chats und Ausführungsdaten gelangen nicht in gemeinsame Suchbestände. Unklare Rechte verhindern Aufnahme oder Abfrage. Gruppenentzug und Sperren erfassen auch direkte Objektzugriffe und zwischengespeicherte Rechte.

Quellen: [12] · [2] S. 11–12 · [9]

KI-RAG-003 – Schutz abgeleiteter Daten

Geltung: Beide Szenarien

Festlegung

Schutz, Herkunft, Aufbewahrung, Berichtigung und Löschung einer Quelle gelten auch für Quelldatei, extrahierten Text, Textabschnitte, Suchvektoren, Indexeinträge, Zwischenspeicher, Gesprächskontext und Sicherungen. Herkunft und konkrete Fundstellen bleiben nachvollziehbar. Unzulässiger Zugriff ist unabhängig von Löschrufen gesperrt. Eine Wiederherstellung wendet aktuelle Rechte, Sperren und Löschrufen an.

Betrieb und Anwendung

Quellkennung, konkrete Fundstellen, Version und Rechte verbinden Dokument, extrahierten Text, Textabschnitte, Suchvektoren, Index und Ergebnis. Zweckbezogene Aufbewahrungs- und Löschregeln erfassen auch Zwischenspeicher, Gesprächskontext und Sicherungen; ihre Ausführung wird im bestehenden Löschverfahren dokumentiert. Aufbewahrte Sicherungen stehen nicht für die reguläre Suche bereit. Im Cloud-Szenario werden gespeicherte Eingaben und Ergebnisse beim Anbieter entsprechend dem freigegebenen Verarbeitungsumfang behandelt.

Quellen: [12] · [11] · [9]

KI-RAG-004 – Persönliche Inhalte und gemeinsame Wissensbestände**Geltung: Beide Szenarien****Festlegung**

Persönliche Chats, Dateien, Ergebnisse und interne Ausführungsdaten sind vor unberechtigtem Nutzerzugriff geschützt. Chats und Agentenarbeit werden nicht automatisch in gemeinsame Wissensbestände übernommen. Die bereitstellende Person entscheidet im Rahmen ihrer Befugnisse über eine gemeinsame Nutzung.

Betrieb und Anwendung

Nutzende wählen Inhalte, zulässige Ablage und berechtigten Empfängerkreis für eine Weitergabe. Die Freigabe eines Gesprächs oder Ergebnisses ist von der Aufnahme in einen gemeinsamen Suchbestand getrennt. Persönliche Arbeitsinhalte bleiben ohne entsprechende Freigabe außerhalb gemeinsamer Wissensbestände.

Quellen: [12] · [1] S. 25–29

9.11 Agentische Anwendungen**KI-AGT-001 – Agentische Projektarbeit im Nutzerkontext****Geltung: Beide Szenarien****Festlegung**

Der Projektassistent führt genehmigte Datei- und Befehlsaktionen in der regulären Nutzersitzung aus. Es gelten die Rechte des angemeldeten Benutzers. Die KI-Nutzung verleiht keine zusätzlichen Administratorrechte. Die Ausgangskonfiguration verlangt Einzelgenehmigungen auch für lesende Zugriffe.

Betrieb und Anwendung

Nutzende bestimmen Auftrag, Arbeitsbereich und Projektregeln. Sie legen den Umfang der Aktionsfreigaben nach KI-TOL-001 fest. Projektregeln steuern das Verhalten des Assistenten und erweitern keine Berechtigungen. Für die fachliche Übernahme erzeugter Ergebnisse gilt KI-OUT-001. Die agentische Bearbeitung ist vom verbindlichen Arbeitsstand getrennt. Bearbeitungsrechte und Wiederherstellungsmöglichkeiten begrenzen die Auswirkungen fehlerhafter Aktionen auf den freigegebenen Arbeitsbereich.

Quellen: [2] S. 12–16 · [26] · [27]

KI-AGT-002 – Freigegebene Modellziele für Agenten

Geltung: Beide Szenarien

Festlegung

Der Projektassistent verwendet ausschließlich die für das jeweilige Szenario freigegebenen Modellziele. Ein automatischer Wechsel ist nur innerhalb der freigegebenen Ziele und ihres zulässigen Datenumfangs möglich. Diese Grenzen gelten auch für Erweiterungen, Projektkonfiguration und Fehlerbehandlung.

Betrieb und Anwendung

Im Air-Gap-Szenario sind ausschließlich interne Modellendpunkte verfügbar. Im Cloud-Szenario dürfen auch automatisch einbezogene Dateien, Werkzeugergebnisse und Gesprächsverläufe nur im freigegebenen Umfang übermittelt werden. Fehlt ein zulässiges Ziel, endet die Anfrage. KI-EXT-002 regelt Ausweichziele.

Quellen: [24] · [26] · [27] · [28]

9.12 Schutz vor eingeschleusten Anweisungen

KI-PMT-001 – Abgrenzung von Arbeitsauftrag und Dateninhalt

Geltung: Beide Szenarien

Festlegung

Eingaben, Dokumente, Quellcode und Werkzeugausgaben werden als Daten verarbeitet. Darin enthaltene Anweisungen erweitern weder den erteilten Auftrag noch Werkzeugfreigaben oder Zugriffsrechte. Die Anwendungen setzen diese Grenzen unabhängig vom Modell durch.

Betrieb und Anwendung

Steuernde Vorgaben und Daten werden getrennt verarbeitet. Nutzende bewerten vorgeschlagene Aktionen anhand ihres Auftrags und der erwarteten Wirkung. Eingeschleuste Anweisungen in Projektdateien, Dokumenten oder Suchtreffern erteilen keine Freigabe. Die Belehrung nach Anlage 1 behandelt den Umgang mit solchen Abweichungen.

Quellen: [2] S. 11–16 · [17] · [14]

9.13 Ergebnisprüfung

KI-OUT-001 – Fachliche Prüfung und Verwendung von KI-Ergebnissen

Geltung: Beide Szenarien

Festlegung

Die verwendende Person prüft KI-Ergebnisse vor der fachlichen Übernahme auf Richtigkeit, Vollständigkeit und Eignung für den vorgesehenen Zweck. Sie prüft und testet generierten Code im bestehenden Entwicklungsverfahren. Über Verarbeitung, Verwendung und Weitergabe entscheidet sie im Rahmen ihrer Befugnisse.

Betrieb und Anwendung

Die Prüfung umfasst die maßgeblichen Quellen, fachlichen Aussagen und möglichen Auswirkungen der Verwendung. KI-Ergebnisse durchlaufen die für das Arbeitsergebnis geltenden Qualitäts- und Freigabeverfahren. Eine automatische Übernahme von KI-Erzeugnissen in produktive Systeme erfolgt

nicht. Anlage 1 enthält die entsprechenden Nutzungsregeln. Verbindliche Arbeitsstände werden erst durch die befugte Übernahme eines geprüften Ergebnisses geändert.

Quellen: [1] S. 29–30 · [2] S. 9 und S. 12–16 · [5] S. 29–32

9.14 Werkzeugausführung

KI-TOL-001 – Freigabe von Agentenaktionen

Geltung: Beide Szenarien

Festlegung

Nutzende genehmigen Lesen, Schreiben, Befehlsausführung und Netzwerkzugriff zunächst einzeln. Projektfreigaben sind auf Aktionsart, Arbeitsbereich oder Pfad, zulässige Datenarten, Ziel oder Netzwerkadresse und Geltungsdauer begrenzt und jederzeit widerrufbar. Kritische, privilegierte, externe oder nicht beherrschbar rückgängig zu machende Aktionen benötigen stets eine konkrete befugte Entscheidung.

Betrieb und Anwendung

Bei der Freigabe prüfen Nutzende Auftrag, Aktionsart, Arbeitsbereich, betroffene Daten, Ziel, Dauer und erwartete Wirkung. Projektfreigaben gelten nur innerhalb dieses Umfangs und der bestehenden Nutzerrechte. Weder Modellantworten noch Werkzeugausgaben dürfen Freigaben erteilen, ausweiten oder verlängern. Bei einer Änderung des Auftrags oder unerwartetem Verhalten werden die Freigaben überprüft und erforderlichenfalls zurückgenommen. Anlage 1 beschreibt diese Pflichten. Die interne Verarbeitung der Chatanwendung folgt KI-TOL-002.

Quellen: [2] S. 12–16 · [17] · [13]

KI-TOL-002 – Serverseitige KI-Werkzeuge und interne Ausführung

Geltung: Beide Szenarien

Festlegung

Serverseitige KI-Werkzeuge und Erweiterungen werden ausschließlich durch die Administration eingerichtet und geändert. Nutzende erhalten keinen eigenen Codeausführungszugang auf dem Server. Werkzeugaufrufe unterliegen den zugelassenen Funktionen und Datenrechten.

Betrieb und Anwendung

Ein interner Ausführungsdienst der Chatanwendung ist ausschließlich für diese Anwendung erreichbar. Nutzer- und Sitzungsdaten bleiben getrennt, Rechte und Ressourcen begrenzt. Ungeprüfte Pakete werden nicht automatisch installiert. Werkzeuganbindungen über das Model Context Protocol (MCP) verwenden nur freigegebene Funktionen. Anbieterbetriebene Werkzeuge sind im Cloud-Szenario nicht freigegeben. Für ihre Einführung ist eine gesonderte Fortschreibung erforderlich.

Quellen: [2] S. 10–13 · [16] · [17]

9.15 Ressourcenbegrenzung

KI-THR-002 – Begrenzung von KI-Aufträgen

Geltung: Beide Szenarien

Festlegung

Modellkontext, parallele Anfragen, Laufzeit und Umfang von Agentenschleifen sind begrenzt. Dokumentaufbereitung und Modellverarbeitung halten die zugewiesenen Ressourcen ein. Die betriebliche Arbeit ist unabhängig von der Verfügbarkeit der KI durchführbar.

Betrieb und Anwendung

Überlange oder fehlerhafte KI-Aufträge werden begrenzt oder abgebrochen. Die Prüfung umfasst große Kontexte, wiederholte Werkzeugaufrufe und aufwendige Dokumente. Technische Grenzwerte werden in der jeweiligen Dienstkonfiguration geführt. Im Cloud-Szenario begrenzen zugeordnete Verbrauchs- und Kostenkontingente auch wiederholte Agentenanfragen.

Quellen: [2] S. 14–16 · [17] · [13]

9.16 Erprobung

KI-VAL-001 – Erprobung von Modellen und KI-Funktionen

Geltung: Beide Szenarien

Festlegung

Für neue Modelle und KI-Funktionen werden vor ihrer Bereitstellung Prüfziel, Prüfungsumfang, Testdaten, Annahmen und Annahmekriterien festgelegt. Die ausgeführten Prüfschritte, tatsächlich erzielten Ergebnisse, Abweichungen und die Freigabeentscheidung werden getrennt davon dokumentiert. Die Prüfung umfasst fachliche Eignung, Ergebnisqualität und die Einhaltung der KI-Berechtigungsgrenzen.

Betrieb und Anwendung

Die Testumgebung bildet den betroffenen Modellstand, die Dokumentaufbereitung, Aufgabenprofile und Werkzeugfunktionen ab. Testverantwortliche dokumentieren die tatsächlich ausgeführten Schritte und Ergebnisse. Bewertungen und Selbstauskünfte von Nutzenden werden ausdrücklich als solche gekennzeichnet und nicht als ausgeführte technische Prüfung behandelt. Gezielte Sicherheitsprüfungen erfassen Rechteentzug, direkte Schnittstellenzugriffe, Nutzertrennung und unerwartete Werkzeugaktionen nach KI-THR-001.

Quellen: [2] S. 9–12 · [5] S. 29–32 · [13] · [40]

9.17 Änderungsmanagement

KI-VAL-002 – Fortschreibung bei Änderungen der KI-Nutzung

Geltung: Beide Szenarien

Festlegung

Vor der Bereitstellung von Änderungen an Modellen, Aufgabenprofilen, Kontextaufbereitung und KI-Werkzeugen wird ihre fachliche und sicherheitsrelevante Auswirkung bewertet und dokumentiert. Die Bewertung legt fest, welche bestehenden Prüfungen erneut auszuführen sind. Ändern sich Zweck, zulässige Daten, Berechtigungsgrenzen oder Risikobewertung, wird dieses Konzept gezielt fortgeschrieben.

Betrieb und Anwendung

Ein Produkt- oder Versionswechsel bei unveränderten Konzeptfestlegungen erfordert keine Neufassung, aber eine dokumentierte Auswirkungsentscheidung. Die vorhandene Softwareliste und die betroffenen Dienstkonfigurationen werden aktualisiert. Modellwechsel berücksichtigen KI-MOD-002, Funktionsänderungen KI-VAL-001. Bei Cloud-Modellen werden auch vom Anbieter geändertes Modellverhalten und veränderte Funktionen bewertet. Allgemeine Infrastrukturänderungen folgen dem bestehenden Informationssicherheitskonzept.

Quellen: [2] S. 8 und S. 11–12 · [5] S. 29–32 und S. 45–47 · [38]

9.18 Protokollierung

KI-OPS-001 – Umgang mit KI-Inhalten in Protokollen

Geltung: Beide Szenarien

Festlegung

Die KI-Protokollierung ist auf erforderliche Betriebs- und Sicherheitsmetadaten begrenzt. Zugangsdaten sowie nicht erforderliche Gesprächs-, Dokument- und Ergebnisinhalte werden nicht erfasst. Für jede Protokollart sind Zweck, zugriffsberechtigte Rollen, Aufbewahrungsdauer und Löschozeitpunkt festgelegt. Protokolle werden nicht automatisch in gemeinsame Wissensbestände übernommen.

Betrieb und Anwendung

Erfasst werden zweckgebunden etwa Zeitpunkt, KI-Funktion, Freigabeentscheidung und Fehlerstatus. Fehlertexte und Diagnoseausgaben werden auf unbeabsichtigte Inhaltsübernahme geprüft. Zugriffe sowie fristgerechte Löschung werden im bestehenden Protokollierungs- und Löschoverfahren umgesetzt. Persönliche Gesprächsverläufe werden nach KI-RAG-004 getrennt behandelt. Für den allgemeinen Schutz und Betrieb der Protokollierung gilt KI-GEL-001.

Quellen: [2] S. 12–13 · [5] S. 23–26 und S. 45–47 · [11]

9.19 Betriebsüberwachung

KI-OPS-002 – Behandlung KI-spezifischer Auffälligkeiten

Geltung: Beide Szenarien

Festlegung

Bei fehlerhaften oder unzulässigen KI-Aktionen wird die betroffene Verarbeitung unterbrochen und über die bestehenden Meldewege behandelt. Die Untersuchung erfasst den verwendeten Modellstand, den betroffenen Kontext und die ausgeführten Werkzeugaktionen.

Betrieb und Anwendung

Betroffene Aufgabenprofile, Werkzeuge oder Wissensbestände werden erforderlichenfalls für die weitere KI-Nutzung gesperrt. Die Wiederaufnahme berücksichtigt den geklärten Fehler und die daraus folgenden Änderungen. Für den allgemeinen Vorfallprozess gilt KI-GEL-001.

Quellen: [5] S. 31–32 und S. 45–47 · [2] S. 8 und S. 12–16 · [13]

9.20 Wiederherstellung

KI-OPS-003 – Konsistenz nach Wiederherstellung von KI-Daten

Geltung: Beide Szenarien

Festlegung

Bei der Wiederaufnahme der KI-Verarbeitung stimmen Modellstand, Modellalias, Aufgabenprofile und Suchindizes miteinander überein. Aktuelle Rechte, Zugriffssperren und Löschstände gelten auch für wiederhergestellte KI-Ableitungen.

Betrieb und Anwendung

Nicht zum Modell- oder Aufbereitungsstand passende Suchindizes werden vor der Verwendung neu erzeugt. Wiederhergestellte Inhalte erhalten keine erweiterten Berechtigungen. Die allgemeine Datensicherung und Wiederherstellung richtet sich nach dem bestehenden Informationssicherheitskonzept.

Quellen: [2] S. 11–13 · [16] · [5] S. 45–47

9.21 Außerbetriebnahme

KI-DEC-001 – Entfernung nicht mehr benötigter KI-Bestände

Geltung: Beide Szenarien

Festlegung

Bei der Außerbetriebnahme einer KI-Funktion werden die zugehörigen Modellzugänge, Aufgabenprofile und Werkzeuganbindungen aufgehoben. Alle von der Funktion erzeugten oder gespeicherten KI-Daten werden erfasst. Nicht mehr benötigte Quelldateien, extrahierte Texte, Textabschnitte, Suchvektoren, Indexeinträge, Gesprächskontexte, Protokolle und Zwischenspeicher werden unter Beachtung der geltenden Aufbewahrungs- und Löschbestimmungen entfernt.

Betrieb und Anwendung

Die Prüfung erfasst auch KI-Ableitungen ohne unmittelbar sichtbares Quelldokument. Gemeinsam genutzte Modelle, Wissensbestände und Sicherungen werden im betroffenen Umfang nach dem bestehenden Berechtigungs-, Aufbewahrungs- und Löschverfahren behandelt. Der Abschluss der Entfernung wird nachvollziehbar bestätigt. Für die allgemeine Außerbetriebnahme von Systemen gilt KI-GEL-001.

Quellen: [2] S. 13 · [10] · [5] S. 45–47

9.22 Cloud-Verarbeitung und Ausweichziele

KI-EXT-001 – Freigegebene Cloud-Verarbeitung

Geltung: Cloud-Szenario

Festlegung

Im Cloud-Szenario sind Anbieter, Modellfunktionen, Verarbeitungszwecke und Datenarten ausdrücklich für die KI-Nutzung freigegeben. Die Freigabe umfasst Eingaben, automatisch ergänzten Kontext, Werkzeugrückmeldungen, Ergebnisse und Metadaten. Eine allgemeine Internet- oder Cloud-Freigabe genügt dafür nicht.

Betrieb und Anwendung

Die bestehenden Anbieter-, Vertrags- und Datenschutzverfahren berücksichtigen die KI-Verarbeitung einschließlich Verarbeitungsorten, Unterauftragnehmern und möglichen administrativen Zugriffen. Speicherung, Aufbewahrung, Löschung und Missbrauchsprüfung beim Anbieter sind mit dem zugelassenen Datenumfang vereinbar. Eine Nutzung der Inhalte für Anbietertraining oder Modellverbesserung ist ausgeschlossen. Nicht benötigte Verlaufsspeicherung und Freigabefunktionen sind deaktiviert. Änderungen dieser Bedingungen lösen KI-VAL-002 aus. Die Verarbeitung von Verschlusssachen ist im Cloud-Szenario nicht umfasst.

Quellen: [1] S. 25–29 · [2] S. 4–5 und S. 9–12 · [9] · [8] Art. 26–27 · [10]

KI-EXT-002 – Zulässige Ausweichziele

Geltung: Beide Szenarien

Festlegung

Automatische Ausweichziele sind nur innerhalb des freigegebenen Szenarios und seines Verarbeitungsumfangs zulässig. Die Air-Gap-Umgebung hat keine externen Ausweichziele. Im Cloud-Szenario besitzt jedes Ausweichziel eine eigene Freigabe nach KI-EXT-001.

Betrieb und Anwendung

Ein Ausfall, ein Anmeldefehler oder ein Kapazitätsengpass erweitert keine Ziel- oder Datenfreigabe. Fehlerpfade und Erweiterungen werden auf unerlaubte Zielwechsel geprüft. Ist kein zugelassenes Ziel verfügbar, endet der KI-Auftrag. Private Konten und nicht freigegebene Dienste werden nicht als Ersatz verwendet.

Quellen: [26] · [27] · [2] S. 9–12

10 Wissenssuche

Nutzende stellen Dokumente bewusst über die freigegebene Dokumentenablage bereit. Die Wissenssuche verarbeitet ausschließlich fachlich freigegebene, hinreichend aktuelle und rechtlich nutzbare Inhalte. Verantwortliche Stelle, Prüfentscheidung und nächster Prüftermin bleiben nachvollziehbar. Die Aufnahme und Verarbeitung folgen KI-RAG-001 (Abbildung 7).

Der Aufbereitungsdienst extrahiert die Dokumentinhalte, das Embedding-Modell erzeugt Suchvektoren und der Suchdienst liefert Textstellen als Kontext an das Hauptmodell. KI-RAG-001 regelt die Aufnahme. KI-RAG-002 und KI-RAG-003 führen die Quellrechte durch Textabschnitte, Suchtreffer und Antworten fort. Aufbewahrung, Sperrung und Löschung erfassen Quelldatei, extrahierten Text, Textabschnitte, Suchvektoren, Indexeinträge, Zwischenspeicher, Gesprächskontext und Sicherungen.

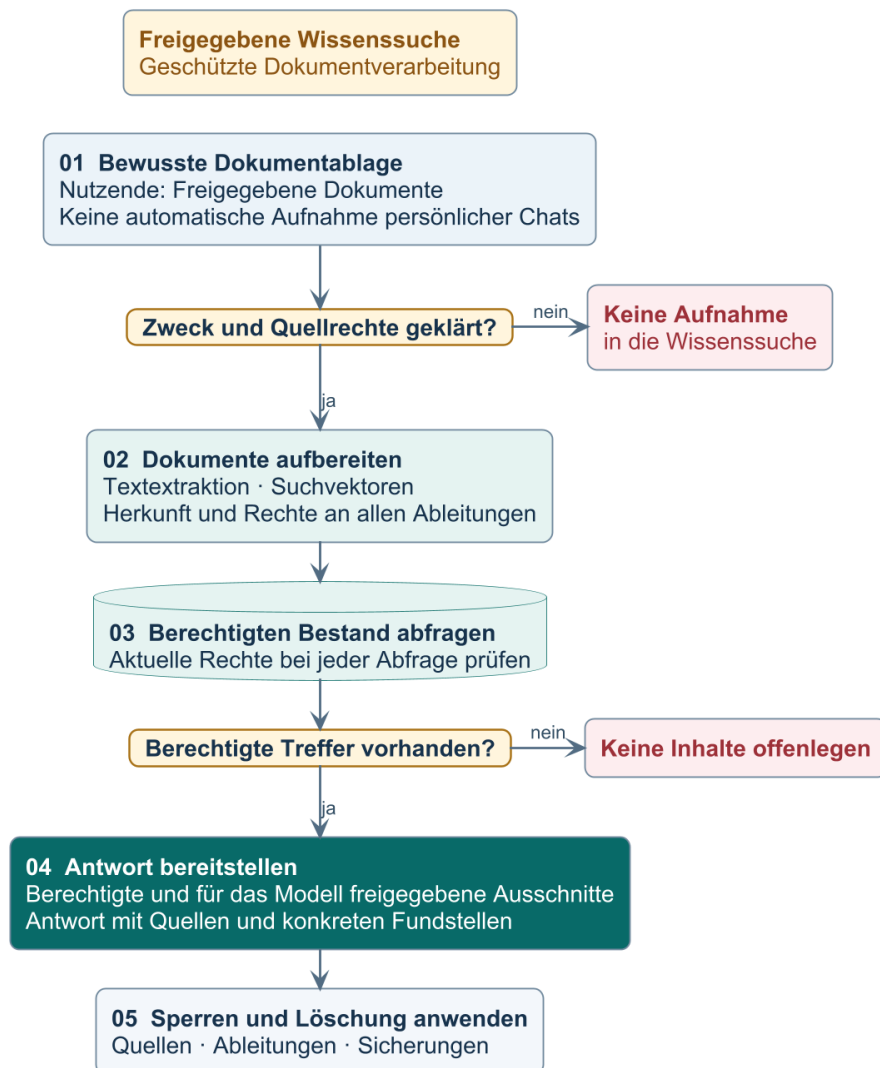


Abbildung 7: Die freigegebene Wissenssuche verarbeitet bewusst abgelegte Dokumente unter durchgängigen Quellrechten.

11 Agentische Anwendungen

Der Projektassistent verwendet den für das Szenario freigegebenen Modellzugang. Freigegebene Datei- und Befehlsaktionen laufen in der regulären Nutzersitzung mit den Rechten des angemeldeten Benutzers. In der Ausgangskonfiguration benötigt jede Aktion eine Einzelgenehmigung, auch das Lesen. Projektfreigaben werden auf Aktionsart, Arbeitsbereich oder Pfad, zulässige Datenarten, Ziel und Geltungsdauer begrenzt. Die Nutzerbelehrung nach Anlage 1 behandelt die Prüfung von Auftrag, Freigabeumfang und erwarteter Wirkung (KI-AGT-001, Abbildung 8).

Nutzende und Teams gestalten ihre lokale Projektarbeit mit Projektregeln und Arbeitsabläufen. Diese erweitern weder Nutzerrechte noch Befugnisse zur Änderung von Serverfunktionen. Modellantworten und Werkzeugausgaben dürfen keine Freigabe erteilen, ausweiten oder verlängern. Den Rahmen für Aktionsfreigaben legt KI-TOL-001 fest. Kritische, privilegierte, externe oder nicht beherrschbar rückgängig zu machende Aktionen erfordern weiterhin die konkrete befugte Entscheidung. Die verbindliche Übernahme von Ergebnissen folgt Kapitel 3.

Quellcode, Dokumente und Werkzeugausgaben können eingeschleuste Anweisungen enthalten. KI-PMT-001 behandelt deren Einfluss auf Agentenaktionen. Die Beschränkung auf freigegebene Modell-

ziele wird nach KI-AGT-002 geprüft, einschließlich veränderter Projektkonfigurationen und Fehlerpfade.

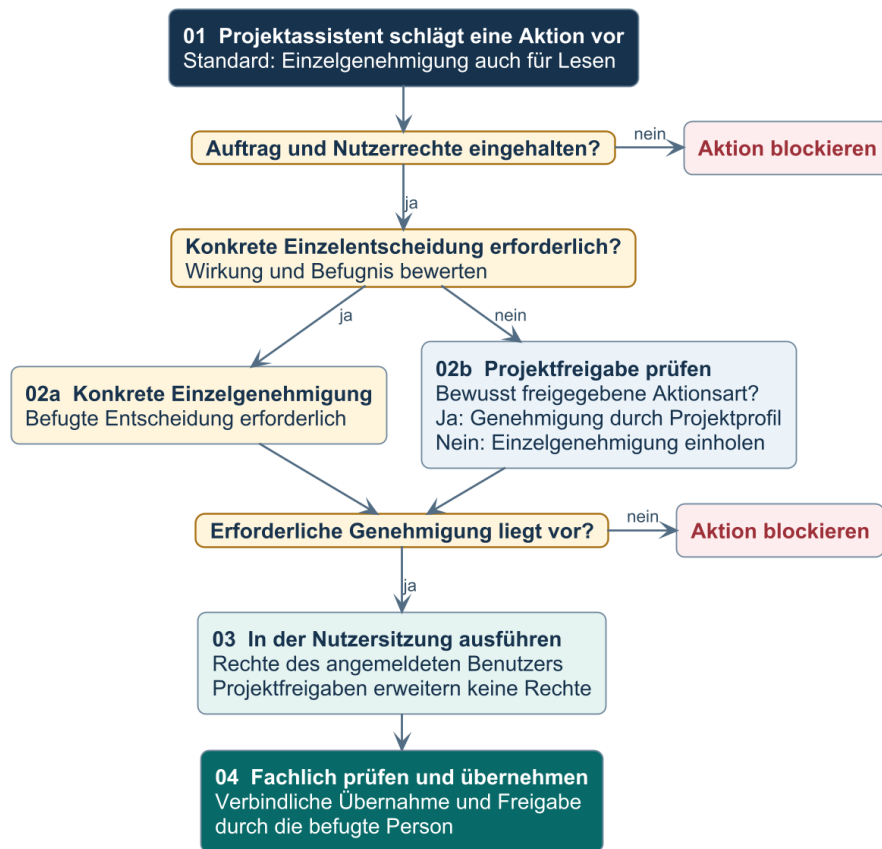


Abbildung 8: Agentenaktionen beginnen mit Einzelgenehmigungen. Projektfreigaben bleiben an Rechte und Wirkung gebunden.

12 Pflege der KI-Funktionen

12.1 Modell- und Funktionsänderungen

Vor einer Erprobung werden Prüfziel, Prüfungsumfang, Testdaten, Annahmen und Annahmekriterien festgelegt. Testverantwortliche dokumentieren getrennt davon die tatsächlich ausgeführten Prüfschritte, Ergebnisse, Abweichungen und Freigabeentscheidung. Bewertungen oder Selbstauskünfte von Nutzenden werden als solche gekennzeichnet und nicht als ausgeführte technische Prüfung behandelt (KI-VAL-001).

Vor der Bereitstellung einer Änderung wird ihre Auswirkung bewertet. Diese Entscheidung legt fest, welche bestehenden Prüfungen erneut auszuführen sind. Modellwechsel werden mit den betroffenen Aufgabenprofilen, Werkzeugfunktionen und Dokumentbeständen erprobt; bei Cloud-Modellen werden auch vom Anbieter geändertes Verhalten und veränderte Funktionen berücksichtigt. Lokale Modellalias bleiben dem geprüften Stand zugeordnet. Änderungen an der Dokumentaufbereitung oder am Embedding-Modell berücksichtigen die Konsistenz vorhandener Suchindizes (KI-MOD-002, KI-VAL-001, KI-VAL-002).

Die Fortschreibung des Konzepts richtet sich nach Änderungen an Zweck, Datenverwendung, KI-Berechtigungsgrenzen und Risikobewertung. Ein Austausch von Programmen oder Betriebsmitteln

bei unveränderten Konzeptfestlegungen wird in der vorhandenen Softwareliste und den betroffenen Konfigurationen gepflegt (KI-GOV-001, KI-VAL-002).

12.2 Protokolle und Auffälligkeiten

Die KI-Protokollierung vermeidet die Übernahme nicht erforderlicher Gesprächs- und Dokumentinhalte. Für jede Protokollart sind Zweck, zugriffsberechtigte Rollen, Aufbewahrungsdauer und Löszeitpunkt festgelegt. Bei einer Auffälligkeit werden der Modellstand, der betroffene Kontext und die tatsächlichen Werkzeugaktionen betrachtet. Der allgemeine Betrieb und die Vorfallobarbeitung folgen dem bestehenden Informationssicherheitskonzept (KI-OPS-001, KI-OPS-002).

12.3 Wiederaufnahme und Außerbetriebnahme

Nach einer Wiederherstellung werden zusammengehörige Modellstände, Aufgabenprofile und Suchindizes auf Konsistenz geprüft. Aktuelle Rechte und Lösstände gelten auch für wiederhergestellte KI-Ableitungen. Bei der Außerbetriebnahme werden Zugänge aufgehoben und alle gespeicherten oder abgeleiteten KI-Daten erfasst. Quelldateien, extrahierte Texte, Textabschnitte, Suchvektoren, Indexeinträge, Gesprächskontexte, Protokolle, Zwischenspeicher und Sicherungen werden nach dem bestehenden Aufbewahrungs- und Lösungsverfahren behandelt; der Abschluss wird nachvollziehbar bestätigt (KI-OPS-003, KI-DEC-001).

13 BSI- und ISO-Zuordnung

ID	Titel	BSI/IT-Grundschutz	ISO-Kennungen
KI-GEL-001	KI-spezifische Ergänzung des Informationssicherheitskonzepts	ISMS.1, ORP.1	ISO/IEC 27001:2022 4.3, ISO/IEC 27001:2022 6.1
KI-GEL-002	Schutzkennzeichnung und kontrollierte Dokumentenführung	ORP.1, CON.10	ISO/IEC 27001:2022 5.2, ISO/IEC 27002:2022 5.12
KI-GOV-001	KI-Funktionen und Softwarezuordnung	ORP.1, OPS.1.1.2	ISO/IEC 42001:2023 A.3, ISO/IEC 27001:2022 5.3
KI-GOV-002	KI-Nutzung und Nutzerbelehrung	ORP.3, ORP.4	ISO/IEC 42001:2023 A.6, ISO/IEC 27002:2022 6.3
KI-REC-001	Zulässige Inhalte im Modellkontext	ORP.5, CON.2	ISO/IEC 42001:2023 4.2, ISO/IEC 27001:2022 4.2
KI-REC-002	Einstufung und Freigabe von KI-Inhalten	CON.10, ORP.4	ISO/IEC 27002:2022 5.12, ISO/IEC 27002:2022 5.13
KI-GOV-003	Bewertung KI-spezifischer Risiken	ISMS.1, OPS.1.1.3	ISO/IEC 27001:2022 6.1, ISO/IEC 42001:2023 6.1, ISO/IEC 23894:2023

ID	Titel	BSI/IT-Grundschutz	ISO-Kennungen
KI-THR-001	Prüfung KI-spezifischer Fehl- und Missbrauchsszenarien	DER.1, APP.6	ISO/IEC 27001:2022 6.1, ISO/IEC 23894:2023
KI-ARC-002	Verarbeitungsgrenzen der Szenarien	NET.1.1, OPS.1.1.10	ISO/IEC 27002:2022 5.14, ISO/IEC 27002:2022 8.20
KI-API-001	Anmeldung und KI-Zugriffsrechte	ORP.4, APP.6, CON.1	ISO/IEC 27002:2022 5.15, ISO/IEC 27002:2022 5.16, ISO/IEC 27002:2022 8.5
KI-IAM-001	Berechtigungen für KI-Nutzung und KI-Verwaltung	ORP.4, CON.7	ISO/IEC 27002:2022 5.15, ISO/IEC 27002:2022 5.16, ISO/IEC 27002:2022 8.2
KI-API-002	Serverseitige Grenzen für Modellzugriffe	APP.6, DER.1	ISO/IEC 27002:2022 8.26, ISO/IEC 27002:2022 8.28
KI-MOD-001	Prüfung bereitgestellter Modelle	OPS.1.1.10, OPS.1.1.6	ISO/IEC 27002:2022 5.21, ISO/IEC 27002:2022 8.19
KI-MOD-002	Austauschbare Modellstände mit stabilen Modellaliasen	OPS.1.1.3, OPS.1.1.6	ISO/IEC 42001:2023 A.6, ISO/IEC 5338:2023
KI-TRN-001	Keine Änderung von Modellgewichten	APP.6, OPS.1.1.3	ISO/IEC 42001:2023 A.6, ISO/IEC 5338:2023
KI-RAG-001	Aufnahme von Dokumenten in den KI-Kontext	APP.6, SYS.1.6	ISO/IEC 27002:2022 8.7, ISO/IEC 27002:2022 8.26
KI-RAG-002	Durchgängige Berechtigungsprüfung und Indextrennung	ORP.4, APP.6	ISO/IEC 27002:2022 5.15, ISO/IEC 27002:2022 8.3
KI-RAG-003	Schutz abgeleiteter Daten	CON.6, CON.3	ISO/IEC 27002:2022 8.10, ISO/IEC 27002:2022 8.13, ISO/IEC 5259-1:2024
KI-RAG-004	Persönliche Inhalte und gemeinsame Wissensbestände	CON.6, APP.6	ISO/IEC 27002:2022 8.10, ISO/IEC 27002:2022 8.12
KI-AGT-001	Agentische Projektarbeit im Nutzerkontext	ORP.4, APP.6	ISO/IEC 27002:2022 8.2, ISO/IEC 27002:2022 8.18
KI-AGT-002	Freigegebene Modellziele für Agenten	APP.6, NET.1.1	ISO/IEC 27002:2022 8.19, ISO/IEC 27002:2022 8.20
KI-PMT-001	Abgrenzung von Arbeitsauftrag und Dateninhalt	APP.6, DER.1	ISO/IEC 27002:2022 8.26, ISO/IEC 27002:2022 8.28

ID	Titel	BSI/IT-Grundschutz	ISO-Kennungen
KI-OUT-001	Fachliche Prüfung und Verwendung von KI-Ergebnissen	APP.6, OPS.1.1.6	ISO/IEC 42001:2023 A.8, ISO/IEC 25059:2023
KI-TOL-001	Freigabe von Agentenaktionen	ORP.4, APP.6	ISO/IEC 27002:2022 8.2, ISO/IEC 27002:2022 8.18
KI-TOL-002	Serverseitige KI-Werkzeuge und interne Ausführung	OPS.1.1.10, OPS.1.1.5	ISO/IEC 27002:2022 5.21, ISO/IEC 27002:2022 8.15
KI-THR-002	Begrenzung von KI-Aufträgen	OPS.1.1.1, DER.1	ISO/IEC 27002:2022 8.6, ISO/IEC 27002:2022 8.16
KI-VAL-001	Erprobung von Modellen und KI-Funktionen	OPS.1.1.6, APP.6	ISO/IEC 42001:2023 A.7, ISO/IEC 25059:2023
KI-VAL-002	Fortschreibung bei Änderungen der KI-Nutzung	OPS.1.1.3, OPS.1.1.6	ISO/IEC 27002:2022 8.32, ISO/IEC 5338:2023
KI-OPS-001	Umgang mit KI-Inhalten in Protokollen	OPS.1.1.5, DER.1	ISO/IEC 27002:2022 8.15, ISO/IEC 27002:2022 8.17
KI-OPS-002	Behandlung KI-spezifischer Auffälligkeiten	DER.1, DER.2.1	ISO/IEC 27002:2022 8.16, ISO/IEC 27002:2022 5.24
KI-OPS-003	Konsistenz nach Wiederherstellung von KI-Daten	CON.3, DER.4	ISO/IEC 27002:2022 8.13, ISO/IEC 27002:2022 5.30
KI-DEC-001	Entfernung nicht mehr benötigter KI-Bestände	CON.6, OPS.1.1.2	ISO/IEC 27002:2022 8.10, ISO/IEC 27002:2022 5.11
KI-EXT-001	Freigegebene Cloud-Verarbeitung	OPS.2.2, CON.2	ISO/IEC 27002:2022 5.19, ISO/IEC 27002:2022 5.20, ISO/IEC 42001:2023 A.10
KI-EXT-002	Zulässige Ausweichziele	NET.1.1, APP.6	ISO/IEC 27002:2022 8.20, ISO/IEC 27002:2022 8.26

14 Verzeichnisse

14.1 Quellenverzeichnis

[1] Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung. Erstfassung. PDF-Stand 07.04.2025. Öffentliche Fundstelle. Abgerufen am 02.09.2026.

- [2] Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen. Version 1.0. Stand 06.06.2025. Öffentliche Fundstelle. Abgerufen am 06.10.2026.
- [3] Bundesamt für Sicherheit in der Informationstechnik: BSI-Standard 200-2: IT-Grundschutz-Methodik. Version 1.0. Stand Oktober 2017. Öffentliche Fundstelle. Abgerufen am 03.09.2026.
- [4] Bundesamt für Sicherheit in der Informationstechnik: BSI-Standard 200-3: Risikomanagement. Version 1.0. Stand Oktober 2017. Öffentliche Fundstelle. Abgerufen am 03.09.2026.
- [5] Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung. K-9000/102, Öffentliche Fassung. Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026. Öffentliche Fundstelle. Abgerufen am 02.09.2026.
- [6] Bundesamt für Sicherheit in der Informationstechnik: Stand-der-Technik-Bibliothek. Commit 8a97764ff4f23c2b7945c64344eecbf5a2053db2. Commit vom 27.08.2026. Öffentliche Fundstelle. Abgerufen am 02.09.2026.
- [7] National Institute of Standards and Technology: OSCAL Version 1.1.3 – Catalog JSON Schema. OSCAL 1.1.3. Stand Release vom 26.11.2024. Öffentliche Fundstelle. Abgerufen am 02.09.2026.
- [8] Europäische Union: Verordnung (EU) 2024/1689 über künstliche Intelligenz. ABl. L 2024/1689. Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 12.07.2024. Öffentliche Fundstelle. Abgerufen am 02.09.2026.
- [9] Die Bundesbeauftragte für den Datenschutz und die Informationsfreiheit: KI in Behörden – Datenschutz von Anfang an mitdenken. Handreichung für die Bundesverwaltung. Stand 22.12.2025. Öffentliche Fundstelle. Abgerufen am 02.09.2026.
- [10] Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Künstliche Intelligenz und Datenschutz. Version 1.0. Stand 06.05.2024. Öffentliche Fundstelle. Abgerufen am 17.09.2026.
- [11] Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu empfohlenen technischen und organisatorischen Maßnahmen bei der Entwicklung und beim Betrieb von KI-Systemen. Version 1.0. Stand Juni 2025, veröffentlicht am 17.06.2025. Öffentliche Fundstelle. Abgerufen am 02.09.2026.
- [12] Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu datenschutzrechtlichen Besonderheiten generativer KI-Systeme mit RAG-Methode. Version 1.0. Stand Oktober 2025, veröffentlicht am 17.10.2025. Öffentliche Fundstelle. Abgerufen am 06.10.2026.
- [13] National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile. NIST AI 600-1. Stand 26.07.2024. Öffentliche Fundstelle. Abgerufen am 06.10.2026.
- [14] National Institute of Standards and Technology: Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations. NIST AI 100-2 E2025. Stand Finalfassung 2025, veröffentlicht am 24.03.2025. Öffentliche Fundstelle. Abgerufen am 02.09.2026.

- [15] European Union Agency for Cybersecurity: Multilayer Framework for Good Cybersecurity Practices for AI. Erstveröffentlichung. Stand 2023, veröffentlicht am 15.11.2023. Öffentliche Fundstelle. Abgerufen am 02.09.2026.
- [16] UK National Cyber Security Centre und internationale Partner: Guidelines for Secure AI System Development. Version 1.0. Stand November 2023, veröffentlicht am 26.11.2023. Öffentliche Fundstelle. Abgerufen am 02.09.2026.
- [17] OWASP Foundation: OWASP Top 10 for Large Language Model Applications. Ausgabe 2025. Öffentliche Fundstelle. Abgerufen am 02.09.2026.
- [18] The MITRE Corporation: MITRE ATLAS. Laufend gepflegte Wissensbasis. Öffentliche Fundstelle. Abgerufen am 02.09.2026.
- [19] The Kubernetes Authors: Kubernetes API Reference: NetworkPolicy v1. Online-Dokumentation. Öffentliche Fundstelle. Abgerufen am 02.09.2026.
- [20] Docker, Inc.: Rootless mode. Online-Dokumentation. Öffentliche Fundstelle. Abgerufen am 02.09.2026.
- [21] Podman Project: podman-network. Online-Dokumentation. Öffentliche Fundstelle. Abgerufen am 02.09.2026.
- [22] Ollama: Authentication. Online-Dokumentation. Öffentliche Fundstelle. Abgerufen am 02.09.2026.
- [23] vLLM Project: Security. Online-Dokumentation. Öffentliche Fundstelle. Abgerufen am 02.09.2026.
- [24] Open WebUI: Starting with OpenAI-compatible providers. Online-Dokumentation. Öffentliche Fundstelle. Abgerufen am 02.09.2026.
- [25] Open WebUI: API Endpoints. Online-Dokumentation. Öffentliche Fundstelle. Abgerufen am 02.09.2026.
- [26] Cline Bot Inc.: Cline Model Providers. Commit 0b0ca9b1fa95ed9f3e0891a34f1f9b3904309710. Commit vom 12.05.2026. Öffentliche Fundstelle. Abgerufen am 02.09.2026.
- [27] Anomaly Innovations Inc.: OpenCode Models. Version 2, Online-Dokumentation. Öffentliche Fundstelle. Abgerufen am 02.09.2026.
- [28] ggml-org: llama.cpp. Commit ccc8fd2baa64ab26c7210b02765d3604069ec7ee. Stand README-
Stand 23.08.2026. Öffentliche Fundstelle. Abgerufen am 02.09.2026.
- [29] Deutsche Akkreditierungsstelle GmbH: Was ist Akkreditierung?. Online-Information. Öffentliche Fundstelle. Abgerufen am 02.09.2026.
- [30] Bundesrepublik Deutschland: Gesetz über das Bundesamt für Sicherheit in der Informationstechnik und über die Sicherheit in der Informationstechnik von Einrichtungen. BSIG 2025. Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 02.12.2025. Öffentliche Fundstelle. Abgerufen am 02.09.2026.

[31] Bundesrepublik Deutschland: Sicherheitsüberprüfungsgesetz, § 4 Verschlusssachen. SÜG. Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 20.04.1994. Öffentliche Fundstelle. Abgerufen am 02.09.2026.

[32] Bundesministerium des Innern und für Heimat: Allgemeine Verwaltungsvorschrift zum materiellen Geheimschutz. Verschlusssachenanweisung. Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 13.03.2023. Öffentliche Fundstelle. Abgerufen am 02.09.2026.

[33] International Organization for Standardization / International Electrotechnical Commission: Information security, cybersecurity and privacy protection — Information security management systems — Requirements. ISO/IEC 27001:2022. Stand ISO-Metadaten, Ausgabe 2022-10, veröffentlicht am 01.10.2022. Öffentliche Fundstelle. Abgerufen am 02.09.2026.

[34] International Organization for Standardization / International Electrotechnical Commission: Information security, cybersecurity and privacy protection — Information security controls. ISO/IEC 27002:2022. Stand ISO-Metadaten, Ausgabe 2022-02, veröffentlicht am 01.02.2022. Öffentliche Fundstelle. Abgerufen am 02.09.2026.

[35] International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence — Management system. ISO/IEC 42001:2023. Stand ISO-Metadaten, Ausgabe 2023-12, veröffentlicht am 01.12.2023. Öffentliche Fundstelle. Abgerufen am 02.09.2026.

[36] International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence — Guidance on risk management. ISO/IEC 23894:2023. Stand ISO-Metadaten, Ausgabe 2023-02, veröffentlicht am 01.02.2023. Öffentliche Fundstelle. Abgerufen am 02.09.2026.

[37] International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence (AI) — AI system impact assessment. ISO/IEC 42005:2025. Stand ISO-Metadaten, Ausgabe 2025-05, veröffentlicht am 01.05.2025. Öffentliche Fundstelle. Abgerufen am 02.09.2026.

[38] International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence — AI system life cycle processes. ISO/IEC 5338:2023. Stand ISO-Metadaten, Ausgabe 2023-12, veröffentlicht am 01.12.2023. Öffentliche Fundstelle. Abgerufen am 02.09.2026.

[39] International Organization for Standardization / International Electrotechnical Commission: Artificial intelligence — Data quality for analytics and machine learning (ML) — Part 1. ISO/IEC 5259-1:2024. Stand ISO-Metadaten, Ausgabe 2024-07, veröffentlicht am 01.07.2024. Öffentliche Fundstelle. Abgerufen am 02.09.2026.

[40] International Organization for Standardization / International Electrotechnical Commission: Software engineering — SQuaRE — Quality model for AI systems. ISO/IEC 25059:2023. Stand ISO-Metadaten, Ausgabe 2023-06, veröffentlicht am 01.06.2023. Öffentliche Fundstelle. Abgerufen am 02.09.2026.

[41] Bundesamt für Sicherheit in der Informationstechnik: IT-Grundschutz-Kompendium – öffentliche Baustein- und Anforderungskennungen. Über die Stand-der-Technik-Bibliothek fixierte Referenz. Stand Commitstand 27.08.2026. Öffentliche Fundstelle. Abgerufen am 02.09.2026.

14.2 Glossar und Abkürzungen

Begriff oder Abkürzung	Bedeutung im Konzept
Agentische Anwendung	KI-Anwendung, die im erteilten Auftrag Werkzeuge verwendet. Nutzerrechte und Freigaben begrenzen ihre Aktionen.
Air-Gap	Betriebsumgebung ohne Netzwerkverbindung zum Internet oder zu externen KI-Diensten. Dateiübernahmen erfolgen über ein geregeltes Verfahren.
Anbietertraining	Verwendung von Kundeneinhalten zur Änderung oder Verbesserung eines Anbietermodells. Im Cloud-Szenario dieses Konzepts ausgeschlossen.
API	Application Programming Interface. Programmierschnittstelle, über die Anwendungen festgelegte Funktionen eines Dienstes aufrufen.
Artefakt	Bereitgestellter Modell- oder Softwarebestand einschließlich der für seine Verwendung erforderlichen Bestandteile.
Aufgabenprofil	Vorbereitete Systemvorgaben und Funktionen einer KI-Anwendung. Es verändert weder Modellgewichte noch Berechtigungen.
BfDI	Die Bundesbeauftragte für den Datenschutz und die Informationsfreiheit.
BMI / BMVg	Bundesministerium des Innern / Bundesministerium der Verteidigung.
BSI	Bundesamt für Sicherheit in der Informationstechnik.
Cloud-Inferenz	Verarbeitung einer Anfrage beim freigegebenen Anbieter innerhalb des zugelassenen Verarbeitungsumfangs.
DSK	Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder.
Embedding / Suchvektor	Numerische Darstellung eines Inhalts, mit der inhaltlich ähnliche Textstellen gefunden werden. Sie verändert die Modellgewichte nicht.
Endpunkt / Route	Festgelegter Zugang zu einer Dienstfunktion. Freigaben bestimmen, wer diese Funktion aufrufen darf.

Begriff oder Abkürzung	Bedeutung im Konzept
Fine-Tuning / LoRA / RLHF	Verfahren zur Anpassung eines Modells. Fine-Tuning bezeichnet die Feinabstimmung, Low-Rank Adaptation eine parameterarme Anpassung und Reinforcement Learning from Human Feedback die Anpassung mit menschlicher Rückmeldung. Alle sind hier ausgeschlossen.
Inferenz	Verarbeitung einer Anfrage mit einem vorhandenen Modell. Die Modellgewichte werden dabei verwendet und nicht verändert.
ISO / IEC	Internationale Organisation für Normung / Internationale Elektrotechnische Kommission. Kennungen bezeichnen die herangezogenen Normen.
KI	Künstliche Intelligenz. Hier: Modelle zur Verarbeitung und Erstellung von Text, Quellcode und Dokumentinhalten.
Kontext	Informationen für die Bearbeitung einer Anfrage, etwa die Eingabe, vorherige Gesprächsbeiträge und passende Dokumentstellen.
MCP	Model Context Protocol. Schnittstellenprotokoll zur Anbindung von Werkzeugen und Datenquellen an KI-Anwendungen.
Modellalias	Stabile Kennung für ein freigegebenes Modell. Die Modellzuordnung kann nach Prüfung geändert werden.
Modellgewichte	Beim Training bestimmte Parameter eines Modells. Die hier beschriebene Nutzung verändert diese Parameter nicht.
OCR	Optical Character Recognition. Optische Zeichenerkennung zur Gewinnung von Text aus Bildern oder gescannten Dokumenten.
OSCAL	Open Security Controls Assessment Language. Offenes NIST-Format für strukturierte Sicherheitsanforderungen und ihre Quellen.
Prompt Injection	Anweisung innerhalb bereitgestellter Inhalte, die vom eigentlichen Arbeitsauftrag abweicht. Inhalte erteilen keine zusätzlichen Rechte oder Freigaben.
RAG	Retrieval-Augmented Generation. Ergänzung einer Anfrage um passende Textstellen aus freigegebenen Dokumenten ohne Modelltraining.
Restrisiko	Risiko, das nach Berücksichtigung der umgesetzten Schutzmaßnahmen verbleibt.
Schleuse	Verfahren zur kontrollierten Übernahme von Dateien zwischen getrennten Sicherheitsbereichen. Der Ablauf richtet sich nach den bestehenden Bestimmungen.

Begriff oder Abkürzung	Bedeutung im Konzept
Suchindex	Strukturierter Bestand zur Suche in Dokumenten. Er enthält Verweise und gegebenenfalls Suchvektoren unter den Rechten der Quellen.
Systemvorgaben	Voreingestellte Anweisungen für die Bearbeitung einer Aufgabe durch das Modell. Technische Berechtigungen werden unabhängig davon geprüft.
Training	Ermittlung oder Änderung von Modellgewichten anhand von Daten. Training ist in der Umgebung ausgeschlossen.
Werkzeugaufruf	Aufruf einer freigegebenen Funktion innerhalb des Auftrags und der Nutzerrechte, etwa zum Lesen einer Datei.